

AUDITORÍA DE SISTEMAS DE INFORMACIÓN

PARCIAL DE AUDITORÍA DE SISTEMAS

Resumen completo para el parcial

Unidad 1 · Unidad 2 · Unidad 3 · Unidad 4 (Módulos 1, 2 y 3)

Fuente principal: diapositivas del profesor (Clases N°1 a N°6)

Fuente secundaria: resumen personal (contrastado contra las clases)

Material de estudio orientado a examen · Terminología del profesor

Índice de contenidos

Contenido del documento

- Unidad 1 — Conceptos básicos de Auditoría de Sistemas
- Unidad 2 — Función de la Auditoría de Sistemas de Información
- Unidad 3 — Auditoría de Cumplimiento (SOX, SOC 1, SOC 2, SOC 3)
- Unidad 4 · Módulo 1 — Fundamentos, modelo de riesgos y procedimientos de auditoría
- Unidad 4 · Módulo 2 — Enfoque Top-Down, Dependencias de TI y Tipología de Controles
- Unidad 4 · Módulo 3 — ITGC, pruebas de auditoría y Modelo de las 5 C
- Anexo — Análisis de fuentes: qué se corrigió y qué se agregó respecto de tu resumen

Índice con números de página (si aparece vacío: al abrir en Word aceptá «Sí» al mensaje de actualización, o clic derecho sobre el índice → Actualizar campo):

UNIDAD 1 — Conceptos básicos de Auditoría de Sistemas	5
1.1 ¿Qué es una auditoría?.....	5
1.2 Objetivos de la auditoría	5
1.3 Tipos de auditoría	6
1.4 Normas generales, independencia y ética	6
1.5 Auditoría de Sistemas de Información (SI) y su misión.....	7
1.6 Tipos de controles: preventivos, detectivos y correctivos.....	7
1.7 ITGC vs. controles de aplicación	8
1.8 Control interno	8
1.9 ¿Cómo se implementa? Política, plan, normas y medidas	9
1.10 Control interno vs. auditoría	9
1.11 Modelo COSO.....	10
1.12 ¿Cómo se relaciona todo esto?	11
Autoevaluación de la Unidad 1.....	12
UNIDAD 2 — Función de la Auditoría de Sistemas de Información	13
2.1 Función, elementos clave y objetivos	13
2.2 ¿Quién se encarga? Organización del departamento.....	13
2.3 Gestión de un programa de auditoría	14
2.4 Perfil profesional, CISA y ética.....	15
2.5 Código de ética profesional de ISACA	15
2.6 Normas, modelos y estándares	16
2.7 Marco COBIT	16
2.8 ¿Cómo se relaciona todo esto?	18
Autoevaluación de la Unidad 2.....	19
UNIDAD 3 — Auditoría de Cumplimiento	20
3.1 Definición, importancia y tipos.....	20
3.2 Ley Sarbanes-Oxley (SOX).....	21
3.3 SOC 1	24

3.4 SOC 2 y SOC 3.....	25
3.5 ¿Cómo se relaciona todo esto?	27
Autoevaluación de la Unidad 3.....	27
UNIDAD 4 — MÓDULO 1: Fundamentos, modelo de riesgos y procedimientos de auditoría.....	28
4.1.1 Definición profesional y rol del auditor.....	28
4.1.2 Auditoría no integrada vs. integrada.....	28
4.1.3 Riesgo de auditoría y seguridad razonable	29
4.1.4 Los componentes del riesgo: RI, RC y RD	29
4.1.5 Cuantificación del riesgo y matriz de riesgos.....	31
4.1.6 Procedimientos de auditoría	31
4.1.7 Pruebas de cumplimiento vs. pruebas sustantivas.....	32
4.1.8 Evidencia de auditoría y papeles de trabajo	33
4.1.9 Hallazgos: Modelo de las 5 C.....	34
4.1.10 El informe de auditoría.....	34
4.1.11 ¿Cómo se relaciona todo esto?	35
Autoevaluación del Módulo 1	35
UNIDAD 4 — MÓDULO 2: Enfoque Top-Down, dependencias de TI y tipología de controles.....	36
4.2.1 El enfoque Top-Down	36
4.2.2 Paso a paso de la cadena.....	36
4.2.3 Tipos de controles internos sobre la información financiera (ICFR)	38
4.2.4 Tipología de controles: manual, automatizado e ITDM.....	39
4.2.5 Las cinco dependencias clave de TI.....	40
4.2.6 Controles fuertes vs. débiles: efecto sobre las pruebas sustantivas.....	43
4.2.7 Matriz de Riesgo y Control (RCM)	43
4.2.8 ¿Cómo se relaciona todo esto?	44
Autoevaluación del Módulo 2	44
UNIDAD 4 — MÓDULO 3: ITGC, pruebas de auditoría y Modelo de las 5 C.....	45
4.3.1 ¿Qué es un ITGC y para qué sirve?.....	45
4.3.2 Dominio 1 — Acceso a Programas y Datos	46
4.3.3 Dominio 2 — Gestión de Cambios en Programas.....	48
4.3.4 Dominio 3 — Desarrollo e Implementación de Programas	49
4.3.5 Dominio 4 — Operaciones de Cómputo	51
4.3.6 Los cuatro dominios ITGC: cuadro comparativo	52
4.3.7 Riesgos de TI por dominio (tabla de la clase).....	53
4.3.8 Modelo de las 5 C (redacción técnica de hallazgos)	53
4.3.9 ¿Cómo se relaciona todo esto?	54
Autoevaluación del Módulo 3	55
ANEXO — Análisis de fuentes: qué se corrigió y qué se agregó	56
A.1 Temas que aparecen en las clases	56
A.2 Lo que ya estaba bien explicado en tu resumen	56

A.3 Lo que faltaba o estaba incompleto en tu resumen 56

A.4 Contradicciones o contenido de tu resumen que NO está respaldado por las clases 57

A.5 Temas que reciben más desarrollo (prioridad de estudio) 58

UNIDAD 1 — Conceptos básicos de Auditoría de Sistemas

Objetivo de la clase (diapositivas): definir las diferencias entre los conceptos básicos de la auditoría de sistemas.

1.1 ¿Qué es una auditoría?

Auditoría

DEFINICIÓN → Proceso **sistemático, independiente y documentado** para obtener evidencias y evaluarlas objetivamente.

OBJETIVO → Garantizar **fiabilidad, seguridad y cumplimiento**.

EJEMPLO → Revisar si los empleados dados de baja por RR.HH. siguen teniendo usuario activo en el sistema.

CLAVE PARA EL PARCIAL → *Sistemático + independiente + documentado + basado en evidencia = auditoría.*

1.2 Objetivos de la auditoría

Objetivo	Qué busca	Ejemplo
Fiabilidad / Integridad	Comprobar que registros, informes (financieros, operativos o tecnológicos) e información analizada reflejen la realidad sin sesgos, errores significativos ni fraudes.	Que el saldo del sistema contable coincida con la realidad.
Cumplimiento	Verificar que las actividades se mantengan dentro del marco legal, normativo, regulatorio y de políticas internas vigentes.	Cumplir la Ley 25.326 o SOX.
Eficiencia y Eficacia (Mejora continua)	Evaluar el uso óptimo de los recursos y detectar debilidades en los controles para recomendar acciones correctivas antes de que se materialicen riesgos o pérdidas.	Detectar que no hay revisión de accesos antes de que ocurra un fraude.

MISIÓN vs. OBJETIVOS (nota de la diapositiva)

- **Misión** → responde «¿Para qué existe la función de auditoría?»: dar confianza, transparencia y promover la mejora en toda la organización.
- **Objetivos** → responden «¿Qué busca lograr el auditor en su trabajo cotidiano?»: verificar la veracidad de la información, comprobar que se cumplan las normas y medir la eficiencia de los controles.

1.3 Tipos de auditoría

Tipo	Quién / Qué evalúa	Ejemplo o palabra clave
Interna	Realizada por personal de la organización para evaluar procesos internos.	Área de auditoría interna de la empresa.
Externa	Conducida por terceros independientes para garantizar imparcialidad .	Firma externa que emite una opinión.
De cumplimiento	Verifica el cumplimiento de normativas legales y estándares .	ISO 27001, SOX, Ley 25.326.
Operativa	Evalúa la eficiencia de los procesos.	Procesos operativos de la organización.
De sistemas	Centrada en la seguridad y funcionamiento de los sistemas de información.	Revisión de accesos, cambios, backups.

1.4 Normas generales, independencia y ética

- **Independencia del auditor** (imparcial y objetivo).
- **Planificación adecuada** del trabajo.
- **Evidencia suficiente y competente** (las conclusiones se basan en pruebas adecuadas y fiables).
- **Comunicación efectiva** (hallazgos claros y oportunos).
- **Código de Ética (ISACA)**: secreto profesional, confidencialidad y objeción ante conflictos de interés (**no auditar el propio trabajo**).

Debate en clase: ética e independencia

Caso: un DBA es promovido a Auditor Interno de Sistemas y en su primer mes debe auditar la seguridad de la base de datos de producción que él mismo diseñó e implementó el año anterior.

Cómo se resuelve con las normas de la clase: hay conflicto de interés porque estaría **auditando su propio trabajo**; se pierde la independencia y la objetividad. Debe declarar el conflicto y objetar la asignación, para que la revisión la haga otro auditor. (Resolución armada con la norma de ISACA vista en clase.)

⚠ IMPORTANTE PARA EL PARCIAL

Independencia + objetividad + confidencialidad son la base de la ética. **No auditar el propio trabajo** es el ejemplo que dio el profesor.

1.5 Auditoría de Sistemas de Información (SI) y su misión**Auditoría de SI (o de TI)**

DEFINICIÓN → Proceso de **recoger, agrupar y evaluar evidencias** para determinar si un sistema informatizado **salvaguarda los activos, mantiene la integridad de los datos, lleva a cabo los fines de la organización y utiliza eficientemente los recursos**. Es el **mecanismo metodológico para valorar y evaluar la confianza** que se puede depositar en TI.

CLAVE PARA EL PARCIAL → *La auditoría de SI mide la CONFIANZA que se puede depositar en TI.*

Misión: no se limita a verificar que exista un control; va más allá y pregunta:

- ¿El control fue **diseñado adecuadamente** para el objetivo que se pretende?
- ¿Es **eficiente** (eficacia versus coste)?
- ¿Se **cumple con eficacia en el tiempo**?
- ¿Los **riesgos de TI** relacionados con el control están **mitigados**?

⚠ IMPORTANTE PARA EL PARCIAL

Las cuatro preguntas de la misión (diseño, eficiencia, eficacia en el tiempo, riesgos mitigados) anticipan lo que se verá en la Unidad 4: diseño vs. eficacia operativa.

1.6 Tipos de controles: preventivos, detectivos y correctivos

Tipo	Definición (diapositiva)	Ejemplo de la clase	Momento
Preventivo	Tratan de evitar el hecho .	Software de seguridad que impide accesos no autorizados al sistema.	Antes del incidente
Detectivo	Actúan cuando fallan los preventivos , para conocer cuanto antes el evento.	Registro de la actividad diaria para detectar errores u omisiones.	Durante / después de que ocurre
Correctivo	Facilitan la vuelta a la normalidad cuando se produjeron incidencias.	Recuperación de un fichero dañado a partir de copias de seguridad.	Tras el incidente

CLAVE PARA EL PARCIAL → Preventivo = evita · Detectivo = descubre · Correctivo = recupera.

1.7 ITGC vs. controles de aplicación

La auditoría de SI distingue **dos grandes grupos** de controles en un entorno de TI:

Aspecto	ITGC (Control General)	Control de aplicación
Dónde actúa	Sobre las infraestructuras de tecnología : afecta a todo el entorno informático .	Imbuido en la propia aplicación o software de negocio.
Qué es	Data Center, redes, Active Directory, políticas de parches.	Lógica programada en el código fuente para gestionar la actividad del negocio (validación de rangos, tipos de datos, controles de ingreso).
Ejemplo de la clase	Pedir usuario y contraseña para acceder a SYSACAD.	La validación que impide ingresar una nota superior a 10 .
Analogía del profesor	La reja o puerta principal de una casa.	La termocupla de la cocina (corta el gas ante un fallo o mala manipulación).

⚠ IMPORTANTE PARA EL PARCIAL

ITGC = infraestructura / todo el entorno. Control de aplicación = dentro del software y su lógica. Los ejemplos SYSACAD (login vs. nota > 10) son los del profesor.

1.8 Control interno

Control interno

DEFINICIÓN → **Conjunto de políticas y procedimientos** diseñados para asegurar el **logro de los objetivos** de la organización. Incluye controles **administrativos, financieros, operativos y tecnológicos**.

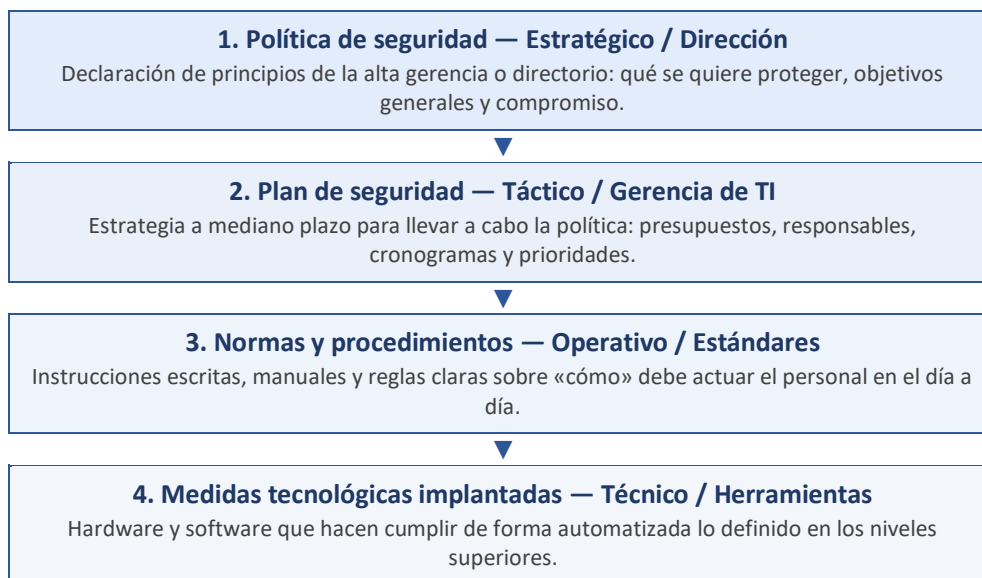
EJEMPLO → La UTN implementa una política de revisión mensual de accesos a SYSACAD para que solo el personal autorizado pueda modificar datos críticos.

Tipos de control interno

Tipo	Qué asegura	Ejemplo de la clase
Administrativos	Cumplimiento de políticas, procedimientos y estructura organizativa para alcanzar objetivos estratégicos.	Organigrama con roles claros: el gerente de ventas no aprueba sus propios gastos, lo hace el director financiero.
Financieros	Exactitud, integridad y transparencia de los reportes financieros.	Banco que exige doble autorización (uno inicia, otro aprueba) en transferencias mayores a AR\$ 50.000.
Operativos	Eficiencia y efectividad de los procesos operativos diarios.	Fábrica que inspecciona sus máquinas a diario para detectar fallos y reducir tiempos de inactividad.
Tecnológicos	Protegen los sistemas informáticos y aseguran la seguridad y continuidad de las operaciones tecnológicas.	Autenticación de dos factores (contraseña + código SMS).

1.9 ¿Cómo se implementa? Política, plan, normas y medidas

La seguridad se implementa en **cuatro niveles**, de lo estratégico a lo técnico:



CLAVE PARA EL PARCIAL → *Política = QUÉ y por qué (Dirección) · Plan = CUÁNDO/CON QUÉ (Gerencia de TI) · Normas y procedimientos = CÓMO (personal) · Medidas tecnológicas = con qué HERRAMIENTAS.*

Ciclo continuo del control interno y la auditoría

El diagrama de la clase muestra un ciclo: **Dirección** (exigencias internas y externas) → **Políticas y directrices** (nivel *política*) → **Estándares, procedimientos, normas y metodologías** (nivel *cultura*) → **Implantar procedimientos de control** → **Comprobación y seguimiento de controles** (la auditoría), que **realimenta a la Dirección**. Por eso el control interno y la auditoría son un ciclo de mejora continua.

1.10 Control interno vs. auditoría

¿Por qué se relacionan?

- **Relación de objeto y examen:** el control interno es el **objeto de estudio**; la auditoría es el **examen o evaluación**. No se puede evaluar algo que no existe.
- **Relación de dependencia metodológica:** el auditor no revisa el 100% de las transacciones ni del código. Primero evalúa la solidez del control interno:
 - Si el control interno es **fuerte** → el auditor confía, **reduce el tamaño de las muestras** y hace pruebas más livianas.
 - Si es **débil o inexistente** → no puede confiar y debe hacer **pruebas sustantivas profundas y exhaustivas**.
- **Relación de retroalimentación:** el control interno previene y mitiga riesgos a diario; la auditoría detecta los «agujeros» que se le pasaron y **exige a la gerencia que los tape** (mejora continua).

Similitudes y diferencias

Similitudes: ambos se alinean con el **marco COSO** (eficiencia, confiabilidad de informes y cumplimiento) e involucran **evaluación de riesgos y monitoreo** de procesos.

Característica	Control interno	Auditoría
Propósito	Prevenir y mitigar riesgos mediante procesos continuos.	Evaluar y verificar periódicamente la efectividad de los controles existentes.
Alcance	Sistema integral y permanente en la organización.	Proceso específico , a menudo externo o independiente.
Ejecutores	La gerencia y todos los empleados .	Audidores internos o externos.

1.11 Modelo COSO

COSO

DEFINICIÓN → Marco integral para el **control interno y la gestión de riesgos**, desarrollado por el **Committee of Sponsoring Organizations of the Treadway Commission** (organización estadounidense fundada en **1985**, para investigar las causas del fraude financiero y promover el control interno). Introducido en **1992** y actualizado en **2013**.

OBJETIVO → Ayudar a las organizaciones a alcanzar sus objetivos en **operaciones, informes y cumplimiento**. Muy usado por empresas públicas para fortalecer controles y cumplir normas como **SOX**.

Los 3 objetivos

Objetivo	Se refiere a...	Ejemplo
Operacionales	Uso eficaz y eficiente de los recursos de la entidad.	Reducir el tiempo de producción.
Información financiera	Preparación y publicación de estados financieros fiables.	Emitir estados financieros sin errores y en fecha.
Cumplimiento	Cumplimiento de leyes y normas aplicables.	Presentar impuestos en tiempo y forma.

Los 5 componentes

Componente (etiqueta del profesor)	Idea central	Ejemplo
1. Entorno de control (Cultura y ética)	El núcleo de un negocio es su personal (integridad, valores éticos, profesionalidad) y el entorno en el que trabaja.	Código de ética firmado por todos los empleados.
2. Evaluación de los riesgos (Identificación de amenazas)	Fijar objetivos y identificar, analizar y tratar los riesgos.	Identificar el riesgo de pérdida de información contable por fallas en el servidor.
3. Actividades de control (Políticas, ITGC y controles de aplicación)	Políticas y procedimientos que dan seguridad razonable de que se afrontan los riesgos.	Separar funciones entre quien aprueba y quien paga.
4. Información y comunicación (Flujo de datos)	Sistemas que permiten captar e intercambiar la información para desarrollar, gestionar y controlar las operaciones.	Alertas automáticas por correo a finanzas cuando vence una factura.
5. Supervisión (Seguimiento continuo y auditoría)	Supervisar todo el sistema y modificarlo cuando corresponda para reaccionar ágilmente.	Revisar mensualmente los reportes de gastos para detectar desvíos frente al presupuesto.

El cubo COSO

Herramienta que integra **tres dimensiones**: los **componentes** (5), los **objetivos** (3) y los **niveles organizativos** (entidad, división, unidad operativa, función). Permite visualizar cómo interactúa cada elemento para gestionar riesgos y controles de manera integral.

Ejemplo práctico del cubo (tomado de tu resumen; la diapositiva 33 lleva ese título)

Una empresa de servicios financieros aplica el cubo para cumplir SOX: **entorno de control** (comité de auditoría independiente a nivel entidad), **evaluación de riesgos** (riesgos de fraude en transacciones a nivel función), **actividades de control** (aprobaciones dobles en pagos a nivel unidad operativa), **información y comunicación** (reportes trimestrales a nivel entidad) y **supervisión** (auditorías internas trimestrales a nivel división).

⚠ IMPORTANTE PARA EL PARCIAL

COSO: 3 objetivos + 5 componentes + niveles organizativos (cubo). Fundado 1985, marco 1992, actualización 2013. Conexión con SOX.

1.12 ¿Cómo se relaciona todo esto?

¿Cómo se relaciona todo esto?

Cadena central de la auditoría:

Riesgo → Control → Evidencia → Prueba del auditor → Hallazgo

Un **riesgo** amenaza un objetivo; la empresa pone un **control** (preventivo, detectivo o correctivo; ITGC o de aplicación) que deja **evidencia**; el auditor la revisa con una **prueba** y, si algo falla, redacta un **hallazgo** que la gerencia debe corregir (ciclo de mejora continua).

Cadena de implementación: política (Dirección) → plan (Gerencia de TI) → normas y procedimientos → medidas tecnológicas → comprobación y seguimiento (auditoría) → vuelve a la Dirección.

Con COSO: los 5 componentes ordenan el control interno; la auditoría es el componente de **supervisión** que verifica que todo funcione.

Autoevaluación de la Unidad 1

LO QUE DEBO PODER EXPLICAR SIN MIRAR

1. Definí auditoría y explicá qué tiene de «sistemático, independiente y documentado».
2. ¿Cuál es la diferencia entre la misión y los objetivos de la auditoría?
3. Diferenciá auditoría interna, externa, de cumplimiento, operativa y de sistemas.
4. ¿Qué pasaría en el caso del DBA promovido a auditor? ¿Qué norma ética se vulnera?
5. Explicá controles preventivos, detectivos y correctivos con un ejemplo de cada uno.
6. ¿En qué se diferencia un ITGC de un control de aplicación? Usá los ejemplos de SYSACAD.
7. Enumerá los cuatro tipos de control interno con un ejemplo cada uno.
8. Ordená y explicá: política de seguridad, plan de seguridad, normas y procedimientos, medidas tecnológicas.
9. ¿Cómo influye la solidez del control interno en el trabajo del auditor?
10. Nombrá los 3 objetivos y los 5 componentes de COSO y explicá qué es el cubo.

UNIDAD 2 — Función de la Auditoría de Sistemas de Información

Objetivo de la clase: comprender la función de la auditoría de SI, su perfil profesional, ética, gestión y normas asociadas.

2.1 Función, elementos clave y objetivos

Función de la auditoría de SI

DEFINICIÓN → Proceso esencial para evaluar la **fiabilidad y seguridad** de los sistemas. Se relaciona con el negocio alineando TI con los **objetivos organizacionales**.

OBJETIVO → **Proteger activos** y garantizar la **continuidad**, porque genera **confianza**.

Elementos clave

Elemento	Qué significa
Independencia	El auditor no tiene conflictos de interés : garantiza imparcialidad en la evaluación.
Objetividad	Analizar los sistemas basándose únicamente en hechos, sin prejuicios .
Evidencia documentada	Registros verificables (documentos o entrevistas) que respaldan los hallazgos y conclusiones.

Objetivos (CID)

Objetivo	Qué garantiza	Ejemplo
Integridad	Que los datos sean precisos y no se alteren sin autorización .	Nadie modifica notas en SYSACAD sin permiso.
Confidencialidad	Protege la información contra accesos no autorizados .	Solo RR.HH. ve los sueldos.
Disponibilidad	Que los sistemas y datos estén accesibles cuando se necesiten .	El sistema de facturación funciona en horario comercial.

IMPORTANTE PARA EL PARCIAL

CID = Confidencialidad, Integridad, Disponibilidad. También aparecen en la ética del auditor y en los ITGC.

2.2 ¿Quién se encarga? Organización del departamento

El **departamento de auditoría de los SI** es el encargado de **planificar, ejecutar y supervisar** las auditorías de los sistemas de información, garantizando seguridad, fiabilidad y cumplimiento normativo. Puede ser **Auditoría Interna** o **Subcontratada (Outsourcing)**.

- **Estructura:** jerárquica, con un líder (p. ej., gerente de auditoría de TI) que coordina equipos especializados; puede ser interno o subcontratado a firmas externas.
- **Roles:** auditores senior, auditores técnicos y asistentes, cada uno con responsabilidades específicas (planificación, ejecución, análisis).

Auditoría interna vs. outsourcing (firma externa)

Aspecto	Auditoría interna (propia)	Outsourcing (firma externa)
Conocimiento	Alto conocimiento de la cultura y procesos.	Curva de aprendizaje inicial sobre el negocio.
Objetividad	Riesgo de perder imparcialidad por relaciones.	Total independencia y neutralidad objetiva.
Especialización	Limitada a las competencias del equipo.	Acceso a expertos en tecnologías complejas.
Estructura de costos	Costo fijo continuo (sueldos, capacitación).	Costo variable según demanda/proyecto.

Roles y jerarquía en el departamento

Rol	Qué hace (diapositiva)
1. Gerente / Líder de auditoría	Planifica el programa anual, gestiona el presupuesto y reporta al Directorio.
2. Auditor senior	Diseña programas de trabajo, lidera auditorías de campo y redacta informes.
3. Auditor técnico (especialista)	Ejecuta pruebas en redes, bases de datos, código fuente y análisis forense.
4. Auditor asistente / junior	Recolecta evidencia, ejecuta pruebas básicas y organiza papeles de trabajo.

2.3 Gestión de un programa de auditoría

Implica **planificación, ejecución y seguimiento** (ciclo continuo).

Fase	Qué se hace	Ejemplo
Planificación	Definir alcance (sistemas a auditar), objetivos (seguridad, cumplimiento, eficiencia), asignar recursos (personal, herramientas como ACL) y crear un cronograma (fechas de auditoría y entrega de informes).	Alcance: ERP o red corporativa.
Ejecución	Recolección de evidencias : entrevistas, revisión de logs, pruebas técnicas (p. ej., pruebas de penetración) y análisis de configuraciones.	Revisar logs del sistema.
Seguimiento y mejora continua	Revisar si las recomendaciones previas (ej. autenticación multifactor) se aplicaron y evaluar su eficacia .	6 meses después, verificar que el firewall recomendado esté instalado y funcionando.

Cronograma anual de auditoría (fases)

Fase	En qué consiste
Walkthroughs (WT)	Entrevistas y recorrido inicial del proceso para entender cómo están diseñados los controles.
Pruebas Interim	Evaluación intermedia (ej. 80% de la muestra de ITGC e ITD).
LCD & Updates	Inspección de la fecha del último cambio (Last Change Date) y actualización de pruebas sobre el 20% restante .
Cierre y pruebas sustantivas	Evaluación de fin de año e informe final .

En el diagrama de la clase: tutoriales/entrevistas (WT) → pruebas Interim de ITGC (80% de las muestras) → inspección de LCD/lista de cambios → confirmación y prueba de dependencias de TI (punto de referencia o línea base) → pruebas de Update de ITGC (20%) → consulta de fin de año. Todo dividido en **Planificación, Ejecución y Completación**.

⚠ IMPORTANTE PARA EL PARCIAL

Walkthrough → Interim (80%) → LCD y Updates (20% restante) → Cierre y pruebas sustantivas. Es el orden del cronograma anual.

2.4 Perfil profesional, CISA y ética

- **Perfil:** conocimientos técnicos, competencias éticas y habilidades analíticas.
- **Requisitos básicos:** certificaciones como **CISA**, que da reconocimiento en auditoría, seguridad, gobierno y riesgo.

CISA (Certified Information Systems Auditor)

DEFINICIÓN → Certificación **reconocida a nivel mundial** que reconoce las aptitudes y conocimientos de un profesional en **auditoría de sistemas de información y gobierno y mantenimiento de tecnología de información**.

Ética del auditor de SI

DEFINICIÓN → Se basa en **independencia, objetividad y confidencialidad**. **Garantiza la credibilidad** de la auditoría.

EJEMPLO → Un auditor descubre una vulnerabilidad en un sistema de banca en línea: la reporta **solo a la gerencia** sin divulgarla (**confidencialidad**) y no acepta presiones para minimizar el hallazgo (**independencia**).

Triángulo del fraude

Vértice	Significado
Oportunidad	Debilidad o falla en los controles internos: es el área donde actúa el auditor de TI.
Presión / Motivación	Necesidades financieras o metas inalcanzables.
Racionalización	Justificación moral del individuo al cometer el hecho.

CLAVE PARA EL PARCIAL → *El auditor de TI actúa sobre la OPORTUNIDAD (controles débiles); presión y racionalización son del individuo.*

2.5 Código de ética profesional de ISACA

Establece normas de conducta para los auditores de SI; garantiza que actúen con integridad y mantengan la confianza en la profesión. Los **7 propósitos**:

Nº	Propósito (resumen)
1	Apoyar la implementación y el cumplimiento de normas y procedimientos para la gobernanza y gestión eficaces de TI (auditoría, control, seguridad, riesgos).

N°	Propósito (resumen)
2	Desempeñar funciones con objetividad, diligencia debida y profesionalismo .
3	Servir a los intereses de las partes interesadas de forma lícita, con altos estándares de conducta , sin desacreditar la profesión.
4	Mantener la privacidad y confidencialidad de la información (salvo exigencia legal); no usarla para beneficio personal ni divulgarla.
5	Mantener la competencia profesional ; realizar solo actividades para las que se está cualificado.
6	Informar a las partes pertinentes de los resultados, revelando todos los hechos significativos que pudieran distorsionar los informes.
7	Apoyar la formación profesional de las partes interesadas.

2.6 Normas, modelos y estándares

Sirven para establecer un **marco estructurado y consistente** que guíe la evaluación, gestión y mejora de los SI. Propósitos con el **ejemplo que dio el profesor**:

Propósito	Ejemplo
Proveer una guía estructurada	COBIT 2019 (procesos para auditar gobernanza y gestión de TI).
Asegurar alineación con objetivos de negocio	ISO/IEC 27001 (gestión de seguridad de la información).
Gestionar riesgos	NIST SP 800-53 (controles de seguridad).
Garantizar cumplimiento normativo y legal (GDPR, SOX)	ISO 38500 (gobernanza de TI).
Mejorar calidad y consistencia	ITIL (gestión de servicios de TI).
Facilitar comunicación y transparencia (lenguaje común)	Informes basados en ISACA o ISO .
Promover la mejora continua (madurez)	CMMI (mide la madurez de procesos).

2.7 Marco COBIT

COBIT

DEFINICIÓN → Marco de trabajo **creado por ISACA** para el **gobierno y la gestión de la TI empresarial**, dirigido a **toda la empresa**. La TI empresarial es **toda** la tecnología y procesamiento de información que se usa para lograr objetivos, **no se limita al departamento de TI**.

OBJETIVO → Buenas prácticas de gobierno y gestión de TI; alinear tecnología y negocio; usarse en auditorías, controles y cumplimiento; reducir riesgos; optimizar recursos.

Gobierno de TI vs. Gestión de TI

Característica	Gobierno de TI	Gestión de TI
Naturaleza	Estratégico .	Operativo .
Enfoque	Qué se debe hacer y por qué .	Cómo hacerlo .

Característica	Gobierno de TI	Gestión de TI
Objetivo	Alinear la tecnología con los objetivos del negocio.	Que los procesos de TI funcionen bien día a día.
Responsables	Directivos y alta gerencia.	Gerentes y equipos técnicos.
Ejemplos	Decidir invertir en ciberseguridad, definir políticas de uso de TI, aprobar proyectos clave.	Instalar parches, dar soporte a usuarios, monitorear servidores.
Analogía	El conductor que decide hacia dónde ir.	El mecánico que mantiene el auto funcionando.

¿Qué es un dominio? Los 5 dominios de COBIT

Dominio = grupo de procesos relacionados. Dentro de cada dominio hay **procesos**, y dentro de cada proceso hay **prácticas y objetivos de control**.

Dominio	Tipo	Propósito / pregunta que responde	Procesos clave
EDM — Evaluar, Dirigir y Monitorear	Gobierno (Alta Dirección)	Define la estrategia tecnológica, aprueba inversiones, evalúa el riesgo general. ¿Hacia dónde va la TI? (5 procesos)	EDM03 Riesgo, EDM04 Recursos
APO — Alinear, Planificar y Organizar	Gestión	Arquitectura de sistemas, presupuestos, contratos, política de ciberseguridad. ¿Cómo nos organizamos? (13 procesos)	APO02 Estrategia, APO06 Presupuesto, APO12 Riesgos, APO13 Seguridad
BAI — Construir, Adquirir e Implementar	Gestión	Compra o desarrollo de software, gestión de proyectos, control de cambios. ¿Cómo lo construimos o compramos? (10 procesos)	BAI02 Requisitos, BAI06 Cambios, BAI09 Activos
DSS — Entregar, dar Servicio y Soporte	Gestión	Opera la TI a diario: mesa de ayuda, incidentes, parches, backups. ¿Cómo lo mantenemos funcionando? (6 procesos)	DSS02 Incidentes, DSS03 Problemas, DSS04 Continuidad/Backups, DSS05 Seguridad
MEA — Supervisar, Evaluar y Valorar	Gestión / Auditoría	Mide el rendimiento, verifica control interno y cumplimiento. ¿Lo hacemos bien y en regla? (3 procesos)	MEA01 Rendimiento, MEA02 Control interno, MEA03 Req. externos

IMPORTANTE PARA EL PARCIAL

Solo **EDM** es de Gobierno; **APO, BAI, DSS y MEA** son de Gestión. Mapa mental: EDM (¿hacia dónde?) → APO (¿cómo nos organizamos?) → BAI (¿cómo lo construimos?) → DSS (¿cómo lo mantenemos?) → MEA (¿lo hacemos bien?).

Uso práctico del mapa COBIT para el auditor

- Auditar la **Mesa de Ayuda** → **DSS02**.
- Auditar los **servidores de backup** → **DSS04**.
- Auditar la **seguridad del código fuente o los cambios** → **BAI06**.
- Auditar la **estrategia y presupuesto de TI** → **EDM01, APO02 y APO06**.

Ejemplo al «abrir» DSS04 — Gestionar la Continuidad

Propósito: mantener la disponibilidad de la información y recuperar los activos de TI rápidamente ante un desastre.

- **DSS04.01:** ¿existe un plan de continuidad de negocio redactado y aprobado?
- **DSS04.07:** ¿se hacen los backups según el cronograma (diario/semanal)?
- **DSS04.08:** ¿se hacen pruebas periódicas de restauración para comprobar que no estén corruptos?

Métricas: % de restauraciones exitosas sin pérdida de datos; tiempo para volver a poner en marcha el servidor (**RTO**). **Matriz de responsabilidades:** quién hace el backup, quién aprueba la política y a quién se notifica si falla.

COSO vs. COBIT

Aspecto	COSO	COBIT
Qué es	Modelo de control interno , base para evaluar el control interno de cualquier empresa .	Marco específico para TI : traduce los principios de COSO al mundo tecnológico.
Ejemplo — riesgos	La empresa debe gestionar riesgos .	Define cómo hacerlo en TI (ciberseguridad, backup, continuidad).
Ejemplo — controles	Habla de actividades de control .	Propone controles concretos: roles de acceso, pruebas de sistemas, segregación de funciones .

CLAVE PARA EL PARCIAL → *COBIT es un COMPLEMENTO de COSO: lleva sus principios a la gestión de la tecnología.*

2.8 ¿Cómo se relaciona todo esto?**¿Cómo se relaciona todo esto?**

Ética → **credibilidad** → **confianza**: independencia, objetividad y confidencialidad (respaldadas por el código ISACA) hacen creíble la auditoría; sin credibilidad no hay confianza en TI.

Programa de auditoría: planificación (alcance, objetivos, recursos, cronograma) → ejecución (evidencias) → seguimiento (¿se aplicaron las recomendaciones?). El cronograma anual baja esto a WT → Interim → LCD/Updates → cierre.

Marcos: COSO (control interno general) → COBIT (traducción a TI) → dominios (EDM, APO, BAI, DSS, MEA) → procesos y prácticas que el auditor usa como lista de chequeo (ej. DSS04).

Autoevaluación de la Unidad 2

LO QUE DEBO PODER EXPLICAR SIN MIRAR

1. ¿Qué son independencia, objetividad y evidencia documentada? ¿Qué es CID?
2. Compará auditoría interna y outsourcing en conocimiento, objetividad, especialización y costos.
3. Describí los cuatro roles del departamento de auditoría.
4. Explicá las tres fases del programa de auditoría con un ejemplo.
5. ¿Qué se hace en Walkthrough, Interim, LCD & Updates y Cierre? ¿Qué porcentajes aparecen?
6. ¿Qué es CISA y qué perfil profesional se espera del auditor?
7. Explicá el triángulo del fraude y dónde actúa el auditor de TI.
8. Enumerá los propósitos del código de ética de ISACA.
9. Diferenciá Gobierno de TI y Gestión de TI y ubicá los 5 dominios de COBIT.
10. ¿Cómo se relacionan COSO y COBIT? Dá dos ejemplos.

UNIDAD 3 — Auditoría de Cumplimiento

3.1 Definición, importancia y tipos

Auditoría de cumplimiento

DEFINICIÓN → **Revisión imparcial** de las actividades y registros de una organización para verificar el **cumplimiento de políticas, normas y reglamentos internos y externos**. Puede cubrir ciberseguridad, protección de datos, información financiera, salud y seguridad.

EJEMPLO → Verificar que una empresa cumple la normativa de protección de datos personales.

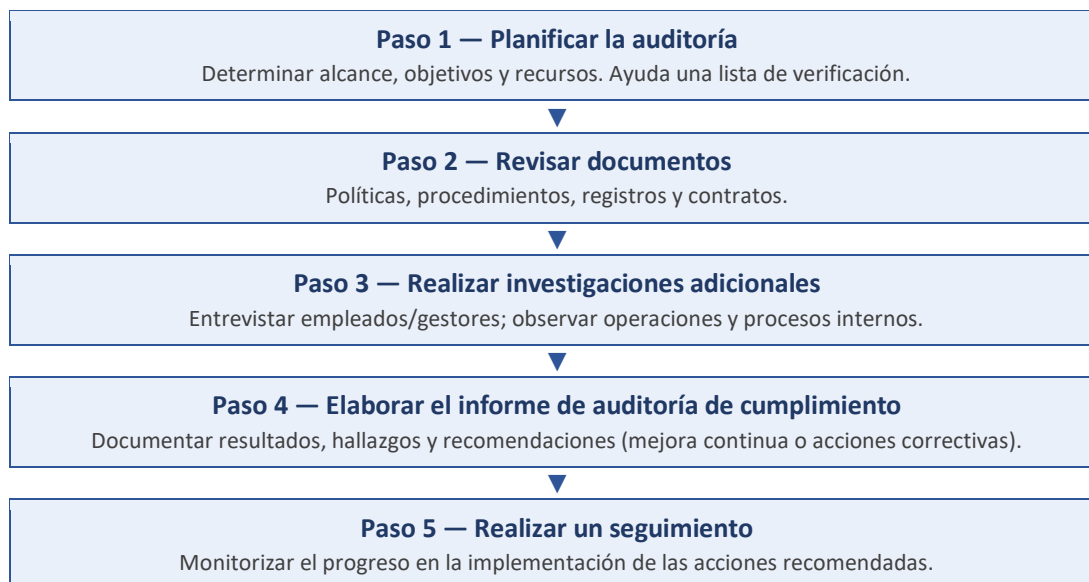
Importancia

Gobiernos y organizaciones aplican requisitos de cumplimiento **para beneficio de consumidores, trabajadores, inversores y otras partes interesadas**. Infringirlos puede dar lugar a **penalizaciones masivas, sanciones y daños a la reputación**. Ejemplo de la clase: infracciones graves al **GDPR** de la UE pueden costar **hasta 20 millones de euros o el 4% de los ingresos anuales mundiales, lo que sea mayor**.

Tipos de auditorías de cumplimiento

- Ciberseguridad.
- Privacidad y protección de datos.
- Informes financieros y seguridad.
- Criterios medioambientales, sociales y de gobernanza (ASG).
- Salud y seguridad.

Pasos de una auditoría de cumplimiento



⚠ IMPORTANTE PARA EL PARCIAL

5 pasos: Planificar → Revisar documentos → Investigaciones adicionales (entrevistas/observación) → Informe → Seguimiento.

3.2 Ley Sarbanes-Oxley (SOX)

SOX

DEFINICIÓN → Ley federal estadounidense de **2002**, impulsada por el senador **Paul Sarbanes** y el representante **Michael Oxley**.

OBJETIVO → **Prevenir el fraude corporativo**: mandatos estrictos sobre cómo se protegen los registros financieros contra la manipulación y **auditores más independientes** de sus clientes.

¿Por qué nace? Enron y WorldCom

Caso	La trampa	Consecuencia
Enron	Creó empresas fantasma (sociedades secretas armadas por los mismos ejecutivos): las deudas se pasaban a esas empresas y en el balance oficial desaparecían . Además, contratos a 20 años por \$10 millones se anotaban como ganancia hoy mismo .	La auditora Arthur Andersen destruyó evidencia (papeles y archivos digitales): origen de la Sección 802 (prohibición de borrar registros) y de la PCAOB .
WorldCom	Gastos comunes (ej. alquiler de líneas telefónicas), que deberían ser gasto y bajar la ganancia hoy, se anotaron en el software contable como inversión a largo plazo (activo) , repartiendo el costo en años.	Balance artificialmente sano al disfrazar gastos como inversiones.

Objetivos principales

- **Proteger a los inversores**: estados financieros precisos y confiables.
- **Aumentar la responsabilidad corporativa**: ejecutivos (CEO, CFO) responsables de la veracidad de los informes.
- **Mejorar los controles internos**: sistemas robustos para prevenir y detectar errores o fraudes.
- **Fortalecer la auditoría independiente**: objetiva y libre de conflictos de interés.

Proceso de cumplimiento de SOX

Paso	Qué se hace
1. Identificación de riesgos	Determinar qué procesos y sistemas impactan los estados financieros (contabilidad, nómina, gestión de ingresos).
2. Documentación de controles	Detallar controles internos (manuales y automatizados): autorizaciones, segregación de funciones, auditorías internas.
3. Pruebas de controles	Evaluar con pruebas regulares si funcionan correctamente.
4. Auditoría externa	Un auditor independiente verifica los controles y emite una opinión sobre su efectividad.
5. Reporte	La gerencia presenta un informe anual sobre los controles internos, validado por los auditores (Sección 404).
6. Certificación	Los ejecutivos firman las certificaciones de las Secciones 302 y 906 .

Secciones clave de SOX

Sección	Título	Contenido	Sanciones
302	Responsabilidad de los ejecutivos	CEO y CFO certifican personalmente exactitud y completitud de los estados financieros (trimestrales y anuales; formularios 10-Q y 10-K). Confirman que revisaron controles internos y que no hay omisiones o errores significativos.	Hasta \$1 millón y/o 7 años de prisión.
404	Evaluación de controles internos	404(a) : la gerencia evalúa y reporta la efectividad de los controles internos sobre informes financieros. 404(b) : los auditores externos opinan sobre esa efectividad (solo empresas públicas grandes). Es de las más costosas y complejas.	—
406	Código de ética	Empresas públicas establecen un código de ética para ejecutivos financieros (conflictos de interés y conducta profesional).	—
409	Divulgación en tiempo real	Informar oportunamente a inversores sobre eventos materiales (quiebras, fraudes).	—
802	Sanciones por manipulación de registros	Penas por alterar, destruir o falsificar documentos financieros para obstruir investigaciones.	Multas y hasta 20 años de prisión.
906	Certificaciones criminales	Refuerza la responsabilidad penal de ejecutivos por certificar informes falsos.	Hasta \$5 millones y/o 20 años .

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

Tu resumen no incluye la sanción de la 906 y dice que la 404 «no especifica sanciones»; las diapositivas dan **hasta \$5 millones y/o 20 años** para la 906. Se prioriza la diapositiva. Tu resumen aclara además que 404 incumplido deriva en informe adverso: idea coherente, pero no figura en las clases.

⚠ IMPORTANTE PARA EL PARCIAL

302 = certificación de CEO/CFO (\$1M / 7 años). 404 = controles internos (a: gerencia, b: auditor externo).
802 = no borrar/alterar registros (20 años). 906 = certificaciones criminales (\$5M / 20 años).

¿Por qué impacta en Sistemas?

Hoy la contabilidad vive en **software y bases de datos**:

- **ITGC (Sección 404)**: probar que solo personal autorizado ingrese a sistemas financieros, que haya **backups operativos** y que los cambios de código se **prueben antes** de salir a producción.
- **Segregación de funciones**: que el software impida que un solo usuario cometa fraude (ej. crear un proveedor fantasma y autorizar su propio pago).
- **Pistas de auditoría / logs inmutables (Sección 802)**: que nadie —ni el administrador de la base de datos— pueda alterar o borrar registros sin dejar huella.

Nace la obligación de contar con sistemas con **logs auditables, segregación de roles automatizada y control de cambios riguroso**.

Control	Práctica deficiente	Práctica adecuada
Acceso de usuarios	Ex-empleado mantiene usuario activo.	Acceso bloqueado apenas se desvincula; el auditor lo verifica.
RespalDOS	Toda la contabilidad en un único servidor sin copias.	Copias diarias en servidores distintos y se prueba su funcionamiento.
Segregación de funciones	Un usuario crea proveedor y autoriza sus pagos.	Otra persona autoriza el pago; el auditor revisa que la separación esté activa.
Logs de auditoría	Se modifican datos contables sin dejar registro.	Cada cambio genera un log (quién, cuándo, qué) que no puede alterarse.

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

La tabla «deficiente vs. adecuada» sale de tu resumen (las diapositivas lo dicen en prosa, ver «¿Por qué impacta en Sistemas?»). Es coherente con las clases, así que sirve como ejemplo, pero no aparece en formato tabla.

PCAOB

La SOX creó el **PCAOB**, sociedad **sin ánimo de lucro** que establece estándares de auditoría financiera y regula a las firmas de contabilidad que auditan empresas públicas. Puede investigar y sancionar con multas de hasta **10.000 USD a particulares** y **2.000.000 USD a organizaciones**.

- **Registro:** las firmas que auditan empresas públicas deben registrarse.
- **Normas de auditoría:** estándares de auditoría, control de calidad e independencia.
- **Inspecciones:** inspecciones regulares a las firmas.
- **Sanciones:** disciplinarias (multas o suspensiones).

¿A quién se aplica SOX?

- **Empresas públicas** registradas en la SEC (incluidas extranjeras que cotizan en bolsas de EE. UU.).
- **Filiales** (subsidiarias) de empresas públicas.
- **Empresas privadas (en algunos casos):** planean una IPO o son contratistas de empresas públicas.
- **Proveedores de servicios:** no están directamente sujetos, pero deben dar informes como **SOC 1** para que sus clientes cumplan.

SOX en Argentina

- **Filiales de multinacionales de EE. UU.** (IBM, Accenture, Google, Ford, P&G): auditan sus sistemas locales (ITGC, accesos, backups, logs) porque la casa matriz consolida balances bajo SOX.
- **Empresas argentinas que cotizan en Wall Street (ADRs)** (Mercado Libre, YPF, Globant, Telecom, Grupo Financiero Galicia): cumplen 100% con SOX y PCAOB: **302** (certificación de CEO/CFO) y **404** (auditoría independiente de controles internos de TI).

Impacto indirecto:

- **BCRA:** Com. «A» 4609 / «A» 7724 y «A» 6042 — equivalente local de SOX para el sector financiero: auditar controles de TI, backups, logs y adoptar el modelo COSO.
- **CNV:** exige comités de auditoría y evaluación del control interno a empresas que emiten acciones o bonos.
- **Ley 27.401** de Responsabilidad Penal Empresaria: programas de Compliance y trazabilidad de datos.

- **Estándar de mercado:** empresas privadas adoptan COBIT e ISO 27001 para venderle a multinacionales o conseguir crédito internacional.

3.3 SOC 1

SOC 1

DEFINICIÓN → Informe de auditoría (marco **SSAE 18**, emitido por el **AICPA**) que evalúa los **controles internos de una organización de servicios relevantes para los estados financieros de sus clientes**. Garantiza que los procesos del proveedor **no introduzcan errores o riesgos** en los informes financieros del cliente.

OBJETIVO → Cumplir **SOX 404** (incluye proveedores externos), dar **confianza al cliente**, **reducir auditorías** (el cliente no audita al proveedor), **mitigar riesgos** y cumplir un **requisito contractual**.

EJEMPLO → Un proveedor de nómina (ADP) entrega su SOC 1 a sus miles de clientes.

¿Quién lo necesita? Organizaciones de servicios (nómina: ADP, Paychex; software contable en la nube: QuickBooks Online, SAP; centros de datos: AWS, Azure; procesamiento de pagos) y clientes sujetos a SOX u otras normativas financieras.

Controles de TI que forman parte del SOC 1: accesos a sistemas, cambios en programas, operación de sistemas (respaldo, continuidad, disponibilidad) y logs y trazabilidad.

SOC 1 Tipo I vs. Tipo II

Aspecto	SOC 1 Tipo I	SOC 1 Tipo II
Enfoque	Diseño e implementación en un momento específico (ej. 30 de junio de 2025).	Diseño y efectividad operativa durante un período (ej. 1/7/2024 al 30/6/2025).
Duración	Un solo punto en el tiempo.	Evaluación continua (6 a 12 meses).
Pruebas	Verifica que los controles estén en su lugar .	Prueba que funcionan efectivamente .
Nivel de assurance	Bajo (solo diseño e implementación).	Alto (diseño y funcionamiento probados).
Ejemplo de uso	Evaluación inicial de «PayrollX».	Cumplimiento de SOX y confianza a largo plazo.

Relación entre SOC 1 y SOX

SOX pide los controles; SOC 1 demuestra que los proveedores los cumplen. Operativamente es similar: el auditor aplica el mismo checklist de **ITGC**:

- **Matriz de accesos:** usuarios dados de baja sin acceso; cuentas privilegiadas (root/admin) controladas.
- **Gestión de cambios:** muestra de peticiones de cambio que pasaron por pruebas y aprobación antes de producción.
- **Operaciones y backups:** logs de copias y pruebas de restauración.
- **Tipo I y II:** primero el **diseño** (la foto de hoy) y luego la **efectividad operativa** (evidencia de 6 a 12 meses).

Diferencia operativa	SOX (interno / in-house)	SOC 1 (proveedor)
Quién audita	Tu equipo de auditoría (o la firma que contratás) audita tu propio servidor ERP.	Un auditor externo (CPA) audita el Data Center o software de AWS o SAP.
Para quién sirve el informe	Informe confidencial para el Directorio y el auditor financiero de tu empresa.	Informe estandarizado que el proveedor reparte a miles de clientes , evitando miles de auditorías individuales.

CUEC — Controles Complementarios del Usuario

Letra chica del SOC 1 (*Complementary User Entity Controls*): el proveedor dice «mis servidores son seguros y los backups funcionan **siempre y cuando el cliente** obligue a sus empleados a usar contraseña segura y Token 2FA». **Resultado:** aunque el proveedor entregue su SOC 1, el auditor de tu empresa igual debe auditar **cómo tu equipo configura y usa** el servicio.

⚠ IMPORTANTE PARA EL PARCIAL

SOC 1 no elimina tu auditoría: los CUEC te obligan a controlar tu lado.

¿Cuándo una empresa sujeta a SOX necesita SOC 1?

- **Dependencia de proveedores externos** que hacen funciones críticas para los informes financieros (nómina, nube).
- **Cumplimiento de la Sección 404:** evaluar todos los controles relevantes, incluidos los de terceros; el SOC 1 (especialmente Tipo II) da evidencia auditada.
- **Reducción de auditorías propias:** sin SOC 1, habría que auditar directamente al proveedor (costoso y complejo).

3.4 SOC 2 y SOC 3

SOC 2

DEFINICIÓN → Informe del AICPA que evalúa los controles de una organización de servicios sobre **seguridad, disponibilidad, integridad de procesamiento, confidencialidad y/o privacidad** de los datos. A diferencia de SOC 1, **no se centra en lo financiero**, sino en la **gestión de datos y la seguridad operativa** (proveedores de tecnología y nube).

OBJETIVO → Confianza del cliente, cumplimiento (GDPR, HIPAA), ventaja competitiva y gestión de riesgos de seguridad y privacidad.

Criterio TSC	Qué garantiza
Seguridad	Protección contra accesos no autorizados, físicos o digitales.
Disponibilidad	Sistemas disponibles según lo acordado.
Integridad de procesamiento	Datos procesados de forma completa, precisa y oportuna.
Confidencialidad	Protección de información sensible o confidencial.
Privacidad	Gestión adecuada de datos personales.

No todos los criterios son obligatorios: cada organización elige cuáles aplicar según el servicio. SOC 2 también tiene **Tipo I** (diseño en un momento) y **Tipo II** (efectividad operativa en un período, 6-12 meses). **Quién lo necesita:** SaaS, centros de datos, proveedores cloud (AWS, Google Cloud), servicios de TI que manejan datos sensibles y clientes que exigen garantías.

SOC 3

DEFINICIÓN → Versión **pública y resumida** del SOC 2: **mismos 5 criterios TSC**, resumen ejecutivo de **5-10 páginas**, de **libre descarga sin NDA**.

OBJETIVO → **Sello de marketing y ventas** para demostrar seguridad a miles de prospectos sin revelar arquitectura ni vulnerabilidades (AWS, Google Cloud, Azure).

SOC 1 vs. SOC 2 vs. SOC 3 (y SOX)

Aspecto	SOX	SOC 1	SOC 2	SOC 3
Naturaleza	Ley federal obligatoria (Congreso EE. UU.)	Informe (SSAE 18 / AICPA)	Informe (AICPA - TSC)	Informe (AICPA - TSC)
Enfoque	Integridad y exactitud contable de la propia empresa.	Controles del proveedor que impactan la contabilidad del cliente.	Ciberseguridad, disponibilidad, confidencialidad e integridad.	Igual que SOC 2, simplificado.
Audiencia	Reguladores (SEC), accionistas, mercado.	Audidores financieros y clientes sujetos a SOX.	Ciberseguridad, riesgos y clientes B2B.	Público general, sitio web y ventas.
Acceso	Público (Formulario 10-K).	Confidencial (clientes y sus auditores).	Confidencial (requiere NDA).	Público (libre descarga, sin NDA).
Criterios	Secciones 302/404 e ITGC / financieros.	Controles financieros internos (a medida del proveedor).	TSC.	TSC.
Ejemplo	Mercado Libre o YPF en Wall Street.	ADP o ERPs contables en la nube.	SaaS, AWS, Azure, data centers.	Sello en la web de Google Cloud o AWS.

Familia SOC: SOC 1 = **contable (privado)**, uso: exigido por auditores de SOX. SOC 2 = **ciberseguridad (privado)**, documento de 50-100 páginas con NDA. SOC 3 = **marketing (público)**, versión ejecutiva corta.

Siglas y organismos clave

Sigla	Qué es
AICPA	American Institute of Certified Public Accountants: regulador/dueño de la metodología de los informes SOC.
CPA	Contador Público Certificado: el único con validez legal para auditar y firmar un informe SOC.
SSAE 18	Norma para SOC 1 (emitida por el AICPA): cómo evaluar controles financieros y contables.
TSC	Norma para SOC 2 y SOC 3: 5 pilares (Seguridad, Disponibilidad, Integridad, Confidencialidad, Privacidad).

PCAOB vs. AICPA

Aspecto	PCAOB	AICPA
Naturaleza	Organismo regulador cuasi-gubernamental (creado por SOX, supervisado por la SEC).	Asociación profesional y privada de contadores.
A quién regula	Firmas que auditan empresas que cotizan (PwC, EY, Deloitte).	Profesionales individuales (CPAs) y sus estándares éticos.
Ámbito	Empresas públicas (Mercado Libre, YPF, Apple) bajo SOX.	Empresas privadas, ONGs y servicios de atestación.
Poder sancionatorio	Poder de policía: multas millonarias, inhabilitar auditores de por vida.	Autorregulación / Código de ética: puede revocar la membresía, sin penas judiciales.

Aspecto	PCAOB	AICPA
Rol en SOC	Indirecto: exige a los auditores de SOX revisar los SOC 1 de proveedores críticos.	Directo y creador: escribe y actualiza SSAE 18 (SOC 1) y TSC (SOC 2 y 3).

⚠ IMPORTANTE PARA EL PARCIAL

SOX = ley obligatoria; SOC = informes de auditoría del AICPA. SOC 1 (financiero, SSAE 18), SOC 2 (TSC, NDA), SOC 3 (TSC, público). PCAOB regula firmas; AICPA escribe las normas SOC.

3.5 ¿Cómo se relaciona todo esto?

¿Cómo se relaciona todo esto?

Fraude (Enron/WorldCom) → SOX → controles → auditoría: los escándalos dieron origen a SOX (302, 404, 802, 906) y a la PCAOB.

SOX → Sección 404 → ITGC en sistemas: la contabilidad vive en software, por eso SOX obliga a probar accesos, cambios, backups, segregación de funciones y logs.

Empresa sujeta a SOX → proveedor externo → SOC 1 → CUEC: si terceriza nómina o nube, pide SOC 1 (Tipo II); el CUEC deja al cliente parte del control.

AICPA/CPA → SOC 1, 2, 3; PCAOB/SEC → SOX: dos mundos distintos: uno normativo obligatorio (SOX) y otro de atestación (SOC).

Autoevaluación de la Unidad 3

LO QUE DEBO PODER EXPLICAR SIN MIRAR

1. Definí auditoría de cumplimiento y listá sus tipos y sus 5 pasos.
2. ¿Por qué nace SOX? Explicá Enron y WorldCom.
3. Enumerá los objetivos de SOX y los 6 pasos del proceso de cumplimiento.
4. Explicá las secciones 302, 404 (a y b), 406, 409, 802 y 906 con sus sanciones.
5. ¿Por qué SOX impacta en la auditoría de sistemas? Dá tres ejemplos.
6. ¿Qué es el PCAOB y cuáles son sus funciones? ¿Cómo se diferencia del AICPA?
7. ¿A quién se aplica SOX y cómo impacta en Argentina (directa e indirectamente)?
8. Diferenciá SOC 1 Tipo I y Tipo II (enfoque, duración, assurance).
9. ¿Qué son los CUEC y por qué el cliente igual debe auditar?
10. Compará SOX, SOC 1, SOC 2 y SOC 3 (naturaleza, audiencia, acceso).

UNIDAD 4 — MÓDULO 1: Fundamentos, modelo de riesgos y procedimientos de auditoría

4.1.1 Definición profesional y rol del auditor

Auditoría de TI (definición profesional)

DEFINICIÓN → Proceso **sistemático de reunir y evaluar evidencia** para determinar si un sistema informático **salvaguarda los activos, mantiene la integridad de los datos, permite alcanzar eficazmente los objetivos organizacionales y utiliza eficientemente los recursos.**

Rol del auditor de sistemas

- **Evaluar el diseño y la efectividad operativa** de los controles tecnológicos.
- **Asegurar la confiabilidad de los datos** que alimentan las decisiones de negocio y los estados financieros.
- **Mitigar riesgos tecnológicos emergentes** (fallas de seguridad, pérdida de datos, errores de software).

Objetivos fundamentales de la auditoría de TI

Objetivo	Qué implica
Salvaguarda de activos	Proteger infraestructura física, servidores, software y datos frente a accesos no autorizados, daños o robo.
Integridad de los datos	Información procesada completa, exacta, oportuna y autorizada .
Disponibilidad continua	Sistemas y servicios críticos operativos cuando el negocio los requiera.
Cumplimiento normativo	Alineación con leyes, estándares y políticas internas (SOX, BCRA, ISO 27001, SOC).

4.1.2 Auditoría no integrada vs. integrada

Aspecto	Auditoría NO integrada	Auditoría integrada
Alcance	Solo estados financieros .	Estados financieros + control interno / TI.
Quién la aplica	Típica en empresas privadas (por elección) .	Obligatoria para empresas públicas bajo SOX (Sección 404); privadas por elección.
Opinión del auditor	Una: razonabilidad de las cifras (situación financiera, resultados, flujos de efectivo). NO dictamina sobre la efectividad del control interno.	Dos opiniones conjuntas: sobre las cifras financieras y sobre la eficacia del control interno (TI y de negocio) sobre la información financiera.

IMPORTANTE PARA EL PARCIAL

No integrada = 1 opinión (cifras). Integrada = 2 opiniones (cifras + control interno), obligatoria en empresas públicas por SOX 404.

4.1.3 Riesgo de auditoría y seguridad razonable

Riesgo de auditoría (RA)

DEFINICIÓN → Riesgo de que el auditor **exprese una opinión inapropiada** cuando los estados financieros contienen **errores materiales**.

OBJETIVO → El objetivo del auditor es realizar la auditoría de manera que se **reduzca el RA a un nivel adecuadamente bajo**, con un **enfoque basado en el riesgo**, para tener seguridad razonable de que los estados financieros están libres de incorrecciones materiales.

CLAVE PARA EL PARCIAL → *El auditor no elimina el riesgo: lo reduce a un nivel adecuadamente bajo.*

Seguridad razonable

DEFINICIÓN → Nivel de certeza **alto pero no absoluto** de que los sistemas y estados contables están libres de errores o irregularidades materiales. Se obtiene reduciendo el RA mediante **debida diligencia profesional** y evidencia **suficiente y apropiada**.

EN AUDITORÍA → ¿Por qué no hay seguridad absoluta (100%)? (1) Limitaciones inherentes de todo control interno (error humano, colusión, elusión por la gerencia). (2) Imposible revisar el 100% de las transacciones (muestreo). (3) Relación costo-beneficio de los controles.

4.1.4 Los componentes del riesgo: RI, RC y RD

$$\text{Riesgo de auditoría (RA)} = [\text{Riesgo inherente (RI)} \times \text{Riesgo de control (RC)}] \times \text{Riesgo de detección (RD)}$$

En el diagrama de la clase: **RI** = «posibles fuentes de posibles errores»; **RC** («controlar el riesgo») se relaciona con la **evaluación del diseño**; **RD** se maneja con **pruebas de eficacia operativa**. **Objetivo metodológico**: diseñar la estrategia de auditoría para reducir el RA a un nivel aceptablemente bajo.

Componente	Definición	¿Quién lo modifica?	Ejemplo de la clase
Riesgo inherente (RI)	Susceptibilidad de un proceso, sistema o cuenta a contener errores significativos o fraude antes de considerar los controles internos .	El auditor NO puede modificarlo : es propiedad del negocio auditado.	Aumenta con: complejidad técnica extrema (microservicios, blockchain), volumen masivo de transacciones en tiempo real, cambios/migraciones recientes, presión o incentivos para manipular datos.
Riesgo de control (RC)	Riesgo de que los controles internos de la empresa no prevengan ni detecten oportunamente un error material o falla de seguridad.	El auditor NO lo modifica : solo lo evalúa (diseño + pruebas de control). Lo determina la calidad de los controles de la empresa.	ITGC robustos → RC bajo . Fallas de contraseñas, falta de MFA, ausencia de control de cambios → RC alto .
Riesgo de detección (RD)	Riesgo de que los procedimientos y pruebas del propio auditor no detecten un error o vulnerabilidad existente.	Es el ÚNICO que el auditor controla directamente , mediante naturaleza, oportunidad y alcance de sus pruebas.	Ampliar muestras, hacer pruebas sustantivas, analizar el 100% con CAATs.

Riesgo de incorrección material (RMM)

DEFINICIÓN → **Unión de RI y RC**: RMM (Risk of Material Misstatement) = Riesgo inherente × Riesgo de control.

EN AUDITORÍA → Pertenece **enteramente a la entidad auditada**. El auditor **no puede modificarlo**; solo **evaluar su nivel** mediante el relevamiento del diseño y las pruebas de control.

⚠ IMPORTANTE PARA EL PARCIAL

¿QUÉ controla el auditor? Solo el **riesgo de detección (RD)**, con la naturaleza, oportunidad y alcance de sus pruebas.

¿QUÉ no puede modificar? El **riesgo inherente** y el **riesgo de control** (juntos, el RMM): son de la empresa auditada; el auditor solo los **evalúa**.

La relación inversa (matriz inversa de decisión)

- A mayor riesgo de control (RC) → menor debe ser el riesgo de detección (RD).
- Si los controles de TI fallan (**RC alto**): el auditor **no puede confiar** en los sistemas y debe **reducir el RD al mínimo**.
- ¿Cómo se reduce el RD? Aumentando el **tamaño de las muestras**, haciendo **pruebas sustantivas directas** y analizando el **100% de las bases de datos con CAATs**.

Si el RC es...	Confianza en los controles	RD aceptable	Qué hace el auditor
Bajo (controles sólidos)	Sí	Mayor (puede tolerarse más)	Muestras más chicas, pruebas sustantivas simplificadas.
Alto (controles débiles)	No	Menor (mínimo)	Muestras mayores, pruebas sustantivas profundas, 100% con CAATs.

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

Tu resumen menciona los tres componentes pero no trae la **relación inversa**, la explicación de **RMM**, ni las razones de **seguridad razonable** que sí figuran en las diapositivas. Se agregaron desde las clases.

Diseño del control vs. eficacia operativa

Aspecto	Evaluación del diseño	Pruebas de eficacia operativa
Paso	Paso 1 (Walkthrough / recorrido).	Paso 2.
Pregunta	¿El control está bien pensado en los manuales y configurado en el software para prevenir errores?	¿El control funcionó de manera consistente durante todo el período auditado (6 a 12 meses)?
Ejemplo (TI)	La política y el formulario de Jira exigen que el Gerente apruebe el acceso antes de crearlo.	Muestrear 30 altas del año y verificar que en las 30 existió la firma previa del Gerente.

⚠ IMPORTANTE PARA EL PARCIAL

Regla de oro: si un control está **mal diseñado**, no tiene sentido probar su eficacia operativa: se clasifica como **deficiente de inmediato**.

4.1.5 Cuantificación del riesgo y matriz de riesgos

En auditoría y gobierno de TI el riesgo **no es subjetivo**: se calcula con **matrices de severidad ponderada**.

$$\text{Puntaje de riesgo (Score)} = \text{Probabilidad (P)} \times \text{Impacto (I)}$$

- **Probabilidad (1 a 5)**: frecuencia, exposición a internet o facilidad con que puede materializarse un evento adverso (1 = rara vez ... 5 = casi seguro).
- **Impacto (1 a 5)**: magnitud del daño financiero directo, sanciones legales de entes reguladores (SEC/BCRA) o parálisis de los sistemas (1 = muy bajo ... 5 = crítico).
- **Escala de salida**: valor discreto de 1 a 25.

Puntaje	Nivel de riesgo (según la matriz 5x5 de la clase)
1 a 6	BAJO
8 a 12	MEDIO / MODERADO
14 a 25 (15, 16, 20, 25)	ALTO / CRÍTICO

EJEMPLO

Probabilidad 4 (muy probable) × Impacto 5 (crítico) = **20 → ALTO**. Probabilidad 2 × Impacto 3 = **6 → BAJO**.

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

En la imagen de la matriz el rango medio se lee 8–12 y el alto 14–25; hay celdas de 15 marcadas ALTO y de 9 y 12 marcadas MEDIO. Si el profesor pregunta un umbral exacto, guíate por la matriz de la clase.

La **RCM** (Matriz de Riesgo y Control) se desarrolla en el Módulo 2.

4.1.6 Procedimientos de auditoría

Actividades específicas que los auditores realizan para **evaluar controles y procesos** y obtener **evidencia suficiente y adecuada** sobre la efectividad de los controles.

Procedimiento	En qué consiste	Ejemplo en sistemas	Limitación / nivel
Entrevistas e indagación	Conversaciones formales con desarrolladores, DBAs, oficiales de seguridad y usuarios para entender procesos y políticas.	Entender el flujo real y excepciones.	Por sí sola NO es evidencia suficiente : debe corroborarse con inspección o pruebas técnicas.
Inspección documental y de registros	Examen minucioso de políticas, manuales, contratos SLA, configuraciones de firewalls y logs.	Política de contraseñas en Active Directory; formulario firmado de alta de usuario; aprobación de un ticket en Jira antes del pase a producción.	—
Observación directa	Presenciar (físicamente o remoto) la ejecución en tiempo real de una actividad.	Acceso físico al Centro de Datos (biométrico, guardias); operador ejecutando un batch job nocturno.	Solo valida el momento observado (efecto Hawthorne).
Pruebas de controles	Probar activamente si el control (programado o manual) responde como se especificó.	5 intentos de contraseña incorrecta y ver si se bloquea; transferencia sin token MFA; archivo con formato erróneo para probar validaciones de entrada.	—

Procedimiento	En qué consiste	Ejemplo en sistemas	Limitación / nivel
Reperformance (re-ejecución independiente)	El auditor ejecuta por su cuenta el mismo procedimiento o cálculo del sistema y compara resultados .	Replicar en Python/SQL el cálculo de retención de impuestos o amortización sobre 10.000 registros y contrastar con el ERP.	Evidencia más sólida y confiable.
Análisis de datos (CAATs)	Software especializado (ACL, IDEA, SQL/Python, Alteryx) para analizar grandes volúmenes.	Duplicados en facturas; gaps en secuencias de comprobantes; transacciones en horarios no hábiles o feriados.	Permite revisar el 100% de la población.
Cuestionarios y encuestas	Recopilar información sobre la percepción de los controles por parte de los empleados.	—	—

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

En las diapositivas la herramienta figura escrita «Alterix» (probablemente Alteryx); se mantuvo tal como aparece la fuente en la lista de CAATs.

CLAVE PARA EL PARCIAL → Entrevista sola no alcanza · Reperformance = evidencia más sólida · Observación = efecto Hawthorne · CAATs = 100% de la población.

4.1.7 Pruebas de cumplimiento vs. pruebas sustantivas

Aspecto	Pruebas de cumplimiento (de controles)	Pruebas sustantivas
Evalúan	El funcionamiento de los controles (el CONTROL).	La integridad y exactitud de cifras/datos (el DATO).
Pregunta	¿Se respetó la política de doble factor? ¿Hubo aprobación de cambios?	¿El saldo contable es correcto? ¿La base tiene registros corruptos?
Relación	Si dan resultado satisfactorio , el auditor puede reducir el volumen de pruebas sustantivas .	Se hacen más profundas si los controles fallan.

Instancia	Categoría	Pregunta que responde	En sistemas (TI)
Evaluación del diseño	Prueba de cumplimiento (Fase 1)	¿El control tiene la lógica adecuada para frenar el error?	¿La política y el formulario de Jira exigen aprobación del Gerente antes de crear el acceso?
Eficacia operativa	Prueba de cumplimiento (Fase 2)	¿El control operó sin fallar a lo largo del año?	Muestrear 30 altas y verificar la firma previa en las 30.
Prueba sustantiva	Prueba sustantiva (independiente)	¿Ocurrió el daño/error material directamente?	Script SQL: ¿hay usuarios en la base con saldos alterados o creados sin legajo?

Estructura metodológica de la clase: Auditoría → *Pruebas de cumplimiento* (evalúan el CONTROL: 1. evaluación del diseño, 2. pruebas de eficacia operativa) y *Pruebas sustantivas* (evalúan el DATO: 3. examen directo de saldos y datos).

⚠ IMPORTANTE PARA EL PARCIAL

Cumplimiento = evalúa el CONTROL (diseño + eficacia operativa). Sustantiva = evalúa el DATO. Controles sólidos → menos pruebas sustantivas.

4.1.8 Evidencia de auditoría y papeles de trabajo

Atributos de calidad de la evidencia

Atributo	Tipo de medida	Qué significa
Suficiencia	Cuantitativa	Tamaño adecuado de la muestra, representatividad estadística.
Adecuación / Pertinencia	Cualitativa	Relevancia: vinculada directamente al control probado. Confiabilidad: mayor si viene de fuentes independientes, generada directamente por los sistemas auditados o documentada formalmente.

Papeles de trabajo

DEFINICIÓN → Documentos generados y recopilados durante la auditoría (registros, cédulas, capturas de pantalla, scripts, entrevistas y análisis) para **respaldar las conclusiones y hallazgos**.

OBJETIVO → **Respaldar técnica y legalmente la opinión** del informe; garantizar **trazabilidad y reproducibilidad**; servir de **defensa ante inspecciones** de reguladores (PCAOB, BCRA, CNV).

Estructura estándar de una cédula de papel de trabajo

Componente obligatorio	Contenido
Encabezado	Entidad, sistema auditado, período evaluado, fecha y nombre del auditor.
Objetivo de la prueba	Qué control o riesgo se testea.
Procedimiento realizado	Detalle técnico de los pasos.
Población y muestra	Tamaño del universo y criterio de selección.
Evidencia obtenida	Capturas, consultas SQL, logs exportados.
Conclusión	Dictamen puntual: Satisfactorio / Excepción / Deficiencia .

Excepción vs. deficiencia de control

Concepto	Definición	Ejemplo
Excepción de auditoría	Desviación puntual detectada en una muestra durante la prueba.	1 ticket de cambio sin firma de aprobación de 25 revisados.
Deficiencia de control interno	Cuando el diseño o la operación del control no permite prevenir o detectar errores a tiempo . Puede escalar a Deficiencia Significativa o Debilidad Material (Material Weakness) si el impacto potencial es crítico.	Ausencia total de revisión de accesos.

CLAVE PARA EL PARCIAL → *Excepción = desvío puntual en la muestra · Deficiencia = falla del control · puede escalar a Deficiencia Significativa → Debilidad Material.*

4.1.9 Hallazgos: Modelo de las 5 C

Toda observación en un papel de trabajo o informe debe contener estos cinco elementos (el desarrollo completo y el ejemplo están en el Módulo 3):

C	Pregunta que responde	Se corresponde con
1. Condición	¿Cuál es la situación actual encontrada?	El hecho real .
2. Criterio	¿Cuál era la norma, política o estándar aplicable?	El deber ser .
3. Causa	¿Por qué ocurrió el problema?	La raíz de la falla.
4. Consecuencia	¿Cuál es el riesgo o impacto potencial para el negocio?	El riesgo/impacto .
5. Corrección / Recomendación	¿Qué acción específica debe implementar la gerencia?	La acción a tomar.

4.1.10 El informe de auditoría

Entregable final que **resume resultados, observaciones y conclusiones**. En un SOC 1 se comparte con **clientes y sus auditores**. Componentes:

Componente	Contenido
Opinión del auditor — No modificada	Los controles están bien diseñados y, en SOC 1 Tipo II, funcionan efectivamente.
Opinión del auditor — Modificada	Se identificaron deficiencias significativas : calificada, adversa o con descargo de responsabilidad.
Descripción del sistema	Servicios, procesos y sistemas auditados (aportada por la gerencia).
Controles evaluados	Lista de controles revisados (seguridad de datos, precisión de cálculos).
Resultados de pruebas (SOC 1 Tipo II)	Evidencia de la efectividad, incluyendo excepciones.
Observaciones y recomendaciones	Hallazgos y sugerencias de mejora.
Uso restringido	El SOC 1 solo se comparte con clientes y sus auditores (bajo confidencialidad).

¿Por qué es una «opinión»?

DEFINICIÓN → Pregunta de la clase: al final de una auditoría externa el auditor emite un informe que expresa una **opinión** (no una declaración, punto de vista ni juicio).

EN AUDITORÍA → En auditoría la opinión **no es un punto de vista subjetivo**: es un **dictamen técnico formal, normado y jurídicamente vinculante**, basado en evidencia documentada. Razones: seguridad **razonable**, no absoluta (muestreo); **estimaciones y juicio profesional** (depreciaciones, contingencias); **riesgo de fraude complejo** (colusión, elusión de controles por la alta gerencia); **separación de responsabilidades** (la gerencia prepara la información; el auditor solo evalúa la evidencia y emite su veredicto).

CLAVE PARA EL PARCIAL → El informe expresa UNA OPINIÓN: un dictamen técnico formal, no una opinión subjetiva.

⚠ IMPORTANTE PARA EL PARCIAL

Auditoría externa → informe = OPINIÓN. Modificada: calificada, adversa o con abstención/descargo.
Gerencia prepara, auditor evalúa.

4.1.11 ¿Cómo se relaciona todo esto?

¿Cómo se relaciona todo esto?

Cadena del riesgo: RI (del negocio) × RC (de los controles) = **RMM** (la entidad) → el auditor lo **evalúa** con diseño + eficacia operativa → según el resultado, decide el **RD** que tolera → define **naturaleza, oportunidad y alcance** de sus pruebas → RA bajo.

Cadena de la prueba: Riesgo → Control → Evidencia → Prueba del auditor → Hallazgo (5 C) → Informe con opinión.

Ejemplo integrado: riesgo de accesos indebidos (RI alto) → control: aprobación previa del gerente (RC bajo si funciona) → evidencia: formularios firmados → prueba: 30 altas muestreadas (eficacia operativa) → si hay 1 sin firma: **excepción**; si el control no existe: **deficiencia** → hallazgo con las 5 C.

Autoevaluación del Módulo 1

LO QUE DEBO PODER EXPLICAR SIN MIRAR

1. Definí el riesgo de auditoría y explicá qué significa «nivel adecuadamente bajo».
2. ¿Qué es la seguridad razonable y por qué no puede ser absoluta?
3. Diferenciá auditoría integrada y no integrada (opiniones, obligatoriedad).
4. Definí RI, RC y RD y decí cuál controla el auditor y por qué los otros no.
5. ¿Qué es el RMM y cómo se relaciona con RI y RC?
6. Explicá la relación inversa entre RC y RD y qué hace el auditor si el RC es alto.
7. Diferenciá evaluación del diseño y pruebas de eficacia operativa. ¿Cuál es la regla de oro?
8. Enumerá los procedimientos de auditoría, su limitación y cuál da la evidencia más sólida.
9. Diferenciá pruebas de cumplimiento y sustantivas con un ejemplo de TI.
10. ¿Qué es una excepción y qué es una deficiencia? ¿Cómo escala?
11. Explicá suficiencia y adecuación de la evidencia, y la estructura de un papel de trabajo.

UNIDAD 4 — MÓDULO 2: Enfoque Top-Down, dependencias de TI y tipología de controles

4.2.1 El enfoque Top-Down

Enfoque Top-Down en TI

DEFINICIÓN → Metodología que inicia en los estados contables y riesgos de negocio significativos, y desciende hacia las aplicaciones y la infraestructura técnica.

OBJETIVO → No auditar todo: auditar cada servidor o base sin criterio de **materialidad** es inviable. El auditor enfoca su esfuerzo solo en los sistemas que mueven cifras críticas.

CLAVE PARA EL PARCIAL → Se baja desde las cifras del balance hasta la infraestructura; no se audita TI «porque sí».

La cadena de aseguramiento Top-Down



⚠ IMPORTANTE PARA EL PARCIAL

Este módulo debe quedar muy claro: FSLI → LSPM → Control clave → Dependencia de TI → Software en alcance → ITGC.

4.2.2 Paso a paso de la cadena

Paso 1 — FSLI (Financial Statement Line Items)

DEFINICIÓN → Rubros de los estados financieros que, por su monto o riesgo inherente, tienen impacto material en los saldos de la empresa. Definidos por el equipo de auditoría según riesgo y materialidad.

OBJETIVO → Determinar **dónde mirar**: ordena el alcance de toda la auditoría.

EJEMPLO → Ingresos por facturación (procesamiento masivo), gastos de nómina (retenciones y dispersión bancaria), cuentas por pagar (pagos duplicados, proveedores ficticios), ajustes de balance (asientos manuales del cierre).

EN AUDITORÍA → Los identifica por **materialidad y riesgo inherente**: qué cuentas son grandes o riesgosas.

CLAVE PARA EL PARCIAL → *FSLI = qué cuentas importan (materialidad).*

Paso 2 — LSPM (Likely Sources of Potential Misstatement)

DEFINICIÓN → Puntos de falla del flujo operativo donde una transacción puede registrarse de forma **incompleta, inexacta, extemporánea o fraudulenta**. Se detectan en los procesos de negocio que respaldan cada FSLI.

OBJETIVO → Ubicar **cómo** podría equivocarse cada FSLI, para poner un control justo ahí.

EJEMPLO → **Nómina**: liquidar haberes a personal dado de baja o horas extras no autorizadas. **Ventas**: asentar ingresos sin haber entregado la mercadería. **Tesorería**: autorizar giros a cuentas no validadas.

EN AUDITORÍA → Entiende el proceso (walkthrough) y pregunta «¿dónde puede fallar?».

CLAVE PARA EL PARCIAL → *LSPM = dónde puede fallar el proceso.*

Paso 3 — Controles clave

DEFINICIÓN → Control **cuya falla impediría detectar o prevenir oportunamente** una incorrección material en los estados financieros o procesos críticos. Pueden ser manuales o automatizados y deben alinearse con el marco de control de la gerencia.

OBJETIVO → Mitigar cada LSPM. Características: **alineación directa** con una LSPM; **sin redundancia suficiente** (si falla, ningún otro control lo subsana); **alcance obligatorio** (foco mandatorio de pruebas).

EJEMPLO → El software cruza la nómina con el maestro de personal y bloquea pagos a legajos en estado «Baja».

EN AUDITORÍA → Elige, para cada LSPM, el control que la neutraliza y lo incluye en el alcance de pruebas.

CLAVE PARA EL PARCIAL → *Control clave = si falla, nadie más lo cubre → se prueba sí o sí.*

Paso 4 — Dependencias de TI

DEFINICIÓN → Componentes tecnológicos en los que la organización confía para ejecutar procesos críticos que impactan los informes financieros. **Generan riesgos que deben mitigarse**.

OBJETIVO → Identificar qué parte del control depende del sistema para saber qué probar además del control.

EJEMPLO → Cálculos automatizados, Key Reports, interfaces, EUC/hojas de cálculo, reglas de SoD y accesos restringidos.

EN AUDITORÍA → Para cada control clave pregunta: ¿en qué se apoya del sistema? (reporte, cálculo, interfaz, planilla, rol).

CLAVE PARA EL PARCIAL → *Dependencia de TI = lo que del sistema sostiene al control.*

Paso 5 — Software / aplicaciones en alcance (pila tecnológica)

DEFINICIÓN → Al identificar una dependencia, **todos los componentes tecnológicos que la soportan entran al alcance**: Aplicación (ERP) → Base de datos → Sistema operativo → Nube.

EJEMPLO → Si un reporte crítico sale de SAP, se audita SAP, la base **Oracle**, el servidor **Linux** y la infraestructura de red subyacente.

EN AUDITORÍA → Traza el origen del reporte/cálculo hasta cada capa y las incluye. Las aplicaciones financieramente significativas deben estar dentro del alcance definido por la gerencia.

CLAVE PARA EL PARCIAL → *Una dependencia arrastra toda su pila tecnológica al alcance.*

Paso 6 — ITGC como cimiento

DEFINICIÓN → Controles generales de TI sobre la infraestructura. **Ningún control automatizado, interfaz o reporte es confiable si la infraestructura base es vulnerable.**

EJEMPLO → Si un programador puede entrar un domingo a la base y alterar saldos con un script, los controles de aplicación se anulan; si se implementan cambios sin QA ni aprobación, las reglas de negocio pueden romperse.

EN AUDITORÍA → Prueba los cuatro dominios ITGC (Módulo 3) sobre la pila en alcance.

CLAVE PARA EL PARCIAL → Si los ITGC fallan, todo lo de arriba pierde valor.

¿Cómo se relaciona todo esto?

FSLI dice qué cuenta importa → **LSPM** dice dónde puede fallar → **Control clave** es la defensa → **Dependencia de TI** es lo que del sistema usa esa defensa → **Aplicación en alcance** es el software (y su pila) donde vive → **ITGC** es la infraestructura que garantiza que nadie altera todo eso.

Ejemplo integrado (nómina): FSLI *Gastos por sueldos y cargas sociales* → LSPM *liquidar haberes a legajos inactivos* → control clave *el software bloquea pagos a legajos con estado «Baja»* → dependencia *tabla maestra de RR.HH. y regla en base de datos* → software *ERP de RR.HH. + base + SO* → ITGC *accesos, cambios y operaciones sobre esa pila*.

4.2.3 Tipos de controles internos sobre la información financiera (ICFR)

ICFR

DEFINICIÓN → Control interno sobre la información financiera. Para evaluar su eficacia se evalúan **tres tipos** de controles.

OBJETIVO → Garantizar la **fiabilidad de los informes financieros** (ganancia, nómina, cuentas por pagar, cierre financiero, impuestos).

Tipo	Qué abarca	Ejemplos
ELC — Controles a nivel de entidad	«Techo institucional»: cultura y directivas que rigen toda la organización.	Cultura corporativa, integridad y valores éticos, actitud gerencial, estructura organizacional, capacitación; tono de la dirección, políticas de seguridad aprobadas por el Directorio, capacitación obligatoria (phishing), canal de denuncias.
Controles a nivel de proceso	Procesos de negocio (facturación, nómina, compras, tesorería, cierre), incluyendo controles de revisión.	Controles de prevención y/o detección de errores y fraudes; segregación de funciones.
ITGC — Controles generales de TI	Cimiento tecnológico de los sistemas.	Controles de cambio de programa, desarrollo de programa, acceso lógico y operaciones de computadora.

Mapa relacional de la clase: **ELC** (arriba) → **procesos operativos** (manual puro / automatizado puro / ITDM) → **punto técnico** (dependencias de TI, con C&A obligatorio) → **cimiento tecnológico** (ITGC: seguridad y accesos, gestión de cambios, operaciones de cómputo, desarrollo de software). *Si los ITGC fallan, ningún reporte ni control de negocio es confiable.*

4.2.4 Tipología de controles: manual, automatizado e ITDM

Aspecto	Manual puro	Automatizado puro	Manual dependiente de TI (ITDM)
Quién lo ejecuta	100% humano , sin apoyarse en reportes ni cálculos de TI.	100% sistema : lógica programada en el software o base de datos, sistemática y constante.	Híbrido crítico : un humano revisa y autoriza, pero basado en un reporte del sistema .
Ejemplos	Arqueo de efectivo, inventario ocular en depósito, firmas en el libro de actas.	El sistema rechaza una orden si el CUIT no existe en la base maestra; UNIQUE que impide facturas duplicadas; límites de crédito.	El gerente de finanzas revisa el reporte ERP de «Deudores morosos > 90 días» para la previsión de incobrables.
Riesgo / punto débil	Muy vulnerable a fatiga, omisión y error humano .	Depende de los ITGC (que nadie altere la lógica).	Si el reporte omite datos, la firma del gerente carece de validez.
Qué se prueba	La ejecución humana.	El control programado + ITGC (y sus iteraciones).	Dimensión humana + dimensión tecnológica (C&A).

⚠ IMPORTANTE PARA EL PARCIAL

ITDM = Revisión humana + confiabilidad del reporte (C&A). Para dar por eficaz un ITDM se prueban DOS dimensiones.

Cómo se prueba un ITDM

- **Dimensión humana**: que el revisor **investigó los desvíos, aplicó criterio técnico calificado y documentó la aprobación formal**.
- **Dimensión tecnológica**: que el reporte del sistema fue **Completo y Exacto (C&A — Completeness and Accuracy)**.

CLAVE PARA EL PARCIAL → *Efectividad ITDM = Revisión humana + Confiabilidad del reporte.*

Periodicidad de los controles

Periodicidad	Ejemplo de la clase
Anual	Revisión del código de conducta; actualización de políticas.
Trimestral	Revisión periódica de cuentas de usuario y privilegios (UAR).
Mensual	Conciliaciones bancarias; aprobación del balance de sumas.
Semanal	Monitoreo de pases a producción y tickets de cambios.
Diario / intradiario	Conciliación de interfaces; backups nocturnos.
Por evento (ad hoc)	Baja inmediata de accesos por despidos.

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

Tu resumen presenta la tipología en la Unidad 4 como «manuales / automatizados / manuales dependientes de TI» de forma breve, y trae los ejemplos de gerente-informe de gastos y facturas duplicadas. Las diapositivas usan ejemplos distintos (arqueo de efectivo, UNIQUE de facturas, morosos > 90 días): para el examen, priorizá los del profesor. Tampoco tu resumen incluye la periodicidad.

4.2.5 Las cinco dependencias clave de TI

Tipo (diapositiva)	Descripción
Controles y cálculos automatizados	Controles aplicados por sistemas (comprobaciones de formato, existencia, razonabilidad). Los cálculos son determinaciones matemáticas que hace el sistema en lugar de una persona (ej. depreciación lineal = $(\text{costo} - \text{valor residual}) / \text{vida útil}$; valor de factura = $\text{precio} \times \text{cantidad}$).
Key Reports	Informes o datos generados por el sistema, importantes para la ejecución eficaz de controles relevantes o para pruebas sustantivas .
SoD y acceso restringido (RA)	SoD : asignar responsabilidades a distintas personas para que una sola no pueda cometer y ocultar errores o fraudes. RA : el acceso se restringe a personas autorizadas según sus funciones.
Interfaces	Lógica programada que transfiere datos de un sistema a otro (ej. libro auxiliar de nómina → libro mayor), automática o con descarga/carga manual.
EUC / hojas de cálculo	Herramientas desarrolladas o gestionadas por usuarios finales (Excel, Access) para procesar datos financieros; menos controladas que los sistemas corporativos.

Enfoques de prueba: Baseline vs. Benchmarking

Aspecto	Baseline (línea base)	Benchmarking (punto de referencia)
Qué se hace	Realizar pruebas en el año en curso para establecer el funcionamiento consistente y efectivo de la dependencia.	No realizar pruebas en el año en curso; el funcionamiento consistente y efectivo se basa en revisiones de años anteriores .
Cómo	Se utiliza cuando se evalúa la eficacia operativa .	Se revisa la última modificación de la aplicación o se comparan los códigos para verificar que no cambiaron desde el último período probado.

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

Estas definiciones vienen de tu resumen (que las titula bajo «Unidad 5: Dependencias de TI»). En las diapositivas del Módulo 2 no hay una lámina de Baseline vs. Benchmarking; solo aparece en el cronograma de la Unidad 2 («punto de referencia o línea base»). Son coherentes con lo visto, pero conviene confirmar con el profesor si entran.

Dependencia 1 — Cálculos automatizados

Cálculos automatizados de TI

DEFINICIÓN → Determinación matemática ejecutada por algoritmos o fórmulas embebidas en el sistema **sin intervención del usuario**.

EJEMPLO → Depreciación de activos, retenciones impositivas (IVA, Ganancias), intereses y facturación (precio unitario × cantidad).

EN AUDITORÍA → **Reperformance independiente** en SQL o Python. Hay que entender el **número de iteraciones relevantes**: una iteración ocurre cuando el control se programa para operar de manera diferente según ciertas entradas.

Dependencia 2 — Key Reports y C&A

Key Reports

DEFINICIÓN → Reportes o extracciones SQL del sistema que sirven como **evidencia base para controles humanos o pruebas sustantivas**.

EJEMPLO → Reporte de morosos > 90 días usado por el gerente.

Tipo de informe	Características
Standard report	Predefinido, generado automáticamente, uso general y rutinario, formato fijo, acceso amplio.
Custom report	Creado para una necesidad particular, requiere desarrollo, bajo demanda, formato personalizable, acceso restringido.
Ad hoc query / EUC / spreadsheets	Consultas bajo demanda de usuarios finales; flexibles pero suelen carecer de controles formales .

Atributo C&A	Significado
Compleitud (C)	El informe incluye el 100% de los datos del período, sin filtros ocultos ni omisiones (de la fuente al informe).
Exactitud (A)	Campos, sumatorias, fechas y cálculos lógicos técnicamente precisos (del informe a la fuente).

Cómo se prueba un Key Report (C&A)

Estrategia	Qué se hace
A — ITGCs + parámetros	Validar que el reporte no sufrió cambios en el código y revisar los filtros de fechas ingresados.
B — Conciliación con CAATs	Cruzar el total del reporte contra el Libro Mayor o la base con consulta SQL propia.
C — Inspección de la consulta	Auditar el script SQL para constatar que las cláusulas WHERE no excluyan registros válidos.

Pasos generales (tu resumen): 1) Origen: entender de qué programa proviene; 2) Controles sobre los datos de origen (integridad, exactitud, validez); 3) Funcionamiento del informe (compleitud y precisión); 4) ITGC que protegen el programa y las fuentes. Coincide con las estrategias A–C.

Dependencia 3 — Interfaces

Interfaces de TI

DEFINICIÓN → Mecanismo automático que **transfiere información entre plataformas distintas** (ej. del sistema de nómina al ERP contable). Una interfaz clave es la **conexión entre dos sistemas independientes**.

OBJETIVO → Garantizar **integridad y precisión** de la transferencia de datos.

EN AUDITORÍA → **Riesgos**: pérdida de paquetes, desfasaje en el mapeo de cuentas, duplicación de transacciones por reintentos de red. **Controles**: validación de **totales de control (hash totals)**, registros de transmisión e inspección de **logs de rechazo**. Se prueba de forma similar a los informes clave y se apoya en ITGC de **monitoreo y resolución de lotes (CO.01)**.

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

De tu resumen (no está en las diapositivas): pruebas de aceptación-rechazo con **16 muestras** para integridad (origen → destino) y para precisión (destino → origen), y revisión de código del procedimiento almacenado. Podés usarlo como complemento; el profesor no lo dio con esos números.

Dependencia 4 — EUC

End-User Computing (hojas de cálculo)

DEFINICIÓN → Planillas de Excel, macros o bases Access gestionadas por usuarios finales **fuera del control del departamento central de TI**.

EN AUDITORÍA → **Riesgo crítico**: sin control formal de versiones, sin pistas de auditoría, cualquiera edita fórmulas (carencia de ITGC). **Abordaje**: identificar los Excel que alimentan **asientos de cierre, bloquear celdas y auditar la lógica matemática**.

Dependencia 5 — Segregación de funciones (SoD) y acceso lógico restringido

SoD

DEFINICIÓN → Principio que exige **dividir las responsabilidades operativas y de registro** para que una persona no cometa y oculte un fraude por sí sola.

EJEMPLO → Incompatibilidades de la clase: **Crear proveedor ≠ Autorizar pago; Liquidar sueldos ≠ Ordenar transferencia bancaria; Desarrollar código ≠ Desplegar en producción**.

EN AUDITORÍA → Rol de TI: configurar **matrices de roles** que impidan perfiles cruzados. La SoD se logra con la correcta asignación de roles y derechos de acceso, **apoyados por los ITGC**.

Acceso lógico restringido (RA)

DEFINICIÓN → **Principio de menor privilegio (Least Privilege)**: cada usuario tiene **solo los permisos estrictamente necesarios**.

EN AUDITORÍA → **Bajas oportunas** (desactivación inmediata ante despidos/renuncias informados por RR.HH.); **cuentas privilegiadas** (sa, root, admin) restringidas con herramientas **PAM**; **prohibición de cuentas genéricas compartidas**.

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

De tu resumen: la prueba general de SoD/RA en cinco pasos (comprender funciones, evaluar diseño de accesos, comprobar ITGC, verificar otorgamiento/restricción). Es compatible con las clases, pero el profesor la enuncia con las incompatibilidades y el menor privilegio.

4.2.6 Controles fuertes vs. débiles: efecto sobre las pruebas sustantivas

Escenario	Situación	Consecuencia para el auditor
A — Controles fuertes	Controles automatizados e ITGC operan con eficacia comprobada.	Reduce el tamaño de las muestras y simplifica las pruebas sustantivas.
B — Controles débiles	Los ITGC fallan (ej. accesos irrestrictos a producción).	Se pierde la confianza en los sistemas: el auditor debe auditar el 100% de los datos mediante CAATs .

4.2.7 Matriz de Riesgo y Control (RCM)

RCM

DEFINICIÓN → Mapea **de forma estructurada** cada cuenta financiera, su riesgo de error, el control que lo mitiga y su dependencia técnica.

EN AUDITORÍA → Columnas: **FSLI**, **LSPM**, **Control clave**, **naturaleza y frecuencia** (manual, automatizado o ITDM) y **dependencia de TI** (reporte clave, cálculo o regla SoD).

Columna	Ejemplo de RCM en nómina (clase)
Cuenta FSLI	Gastos por sueldos y cargas sociales.
Fuente de error (LSPM)	Liquidación de haberes a legajos inactivos.
Control clave	El software cruza la nómina con el maestro de personal y bloquea pagos a legajos con estado «Baja».
Tipo de control	Automatizado puro (frecuencia mensual).
Dependencia de TI	Tabla maestra de RR.HH. y regla en base de datos.

Actividad práctica resuelta (caso del analista contable)

«El analista contable descarga diariamente un CSV de transferencias del Home Banking, lo abre en Excel, ejecuta una macro para conciliar contra el ERP y envía un mail al tesorero con las diferencias.»

Pregunta	Resolución de la clase
1. Tipología	ITDM (manual dependiente de TI) con un componente crítico de EUC (macro de Excel).
2. Dependencias de TI	Extracción del archivo plano bancario, macro local en Excel y tablas del ERP contable.
3. Riesgos críticos	El CSV puede editarse en un bloc de notas antes de abrirse en Excel, sin dejar logs; las fórmulas de la macro no tienen control de versiones ni protección de celdas .

4.2.8 ¿Cómo se relaciona todo esto?

¿Cómo se relaciona todo esto?

Riesgo → Control → Evidencia → Prueba → Hallazgo aplicado al Top-Down: el riesgo son las LSPM de un FSLI; el control es el control clave (manual, automatizado o ITDM); la evidencia es el reporte/cálculo/interfaz (dependencia); la prueba es C&A/reperformance/SoD; y si falla, el hallazgo se escribe con las 5 C.

FSLI → LSPM → Control clave → Dependencia TI → Aplicación → ITGC: de arriba hacia abajo se acota el alcance; de abajo hacia arriba, la confianza: **si los ITGC fallan, todo lo de arriba se cae**, y el auditor pasa de muestras chicas a auditar el 100% con CAATs.

Autoevaluación del Módulo 2

LO QUE DEBO PODER EXPLICAR SIN MIRAR

1. ¿Qué es el enfoque Top-Down y por qué no se audita todo en TI?
2. Recorrí la cadena FSLI → LSPM → controles clave → dependencias de TI → software en alcance → ITGC, con un ejemplo de nómina.
3. ¿Qué es un control clave? ¿Por qué es de alcance obligatorio?
4. Definí ICFR y explicá ELC, controles a nivel de proceso e ITGC.
5. Diferencié manual puro, automatizado puro e ITDM con un ejemplo cada uno.
6. ¿Cómo se prueba un ITDM? ¿Qué es C&A?
7. Enumeré las 5 dependencias de TI y el riesgo de cada una.
8. Explicá las tres estrategias para probar un Key Report.
9. ¿Qué riesgos tienen las interfaces y qué controles se esperan? ¿Y las EUC?
10. Explicá SoD, menor privilegio y las incompatibilidades vistas en clase.
11. ¿Qué es una RCM y qué columnas tiene? Resolvé el caso del analista contable.
12. Diferencié Baseline y Benchmarking.

UNIDAD 4 — MÓDULO 3: ITGC, pruebas de auditoría y Modelo de las 5 C

4.3.1 ¿Qué es un ITGC y para qué sirve?

ITGC (Information Technology General Controls)

DEFINICIÓN → Políticas, procedimientos y controles técnicos aplicados a la **infraestructura tecnológica** para garantizar **confiabilidad, integridad y disponibilidad**. Son controles de alto nivel que se centran en la infraestructura y los procesos generales de TI.

OBJETIVO → **Respaldar el funcionamiento continuo y consistente** de los controles de aplicación y de las dependencias de TI. Son esenciales para proteger la integridad de datos, garantizar la disponibilidad y prevenir accesos no autorizados y errores de procesamiento.

EJEMPLO → Doble factor, superusuarios restringidos, backups y pruebas de restauración, cambios con aprobación.

EN AUDITORÍA → Prueba los ITGC de cada dominio sobre cada capa de la pila tecnológica en alcance.

CLAVE PARA EL PARCIAL → *Los ITGC son el cimiento: sostienen a los controles de aplicación y a las dependencias de TI.*

¿Cómo se relaciona todo esto?

Relación ITGC ↔ controles y dependencias de TI: un control automatizado, un reporte clave, una interfaz o una regla de SoD **funcionan bien solo si los ITGC funcionan**. Si un programador puede alterar la base o cambiar el código sin control, ningún reporte o cálculo es confiable. Por eso el auditor prueba las dependencias y los ITGC que las protegen.

Los 4 dominios de ITGC

Nº	Dominio (inglés)	Dominio (español, del profesor)
1	Access to Programs and Data	Acceso a Programas y Datos
2	Program Changes	Gestión de Cambios en Programas
3	Program Development	Desarrollo e Implementación de Programas
4	Computer Operations	Operaciones de Cómputo

La pila tecnológica auditada

Capa	Qué incluye
1 — Aplicación	Menús de usuario, roles de ERP (SAP, Salesforce, plataformas a medida).
2 — Base de datos	Motores relacionales y NoSQL (Oracle, PostgreSQL, SQL Server).
3 — Sistema operativo	Servidores corporativos (Linux, Windows Server, AIX).
4 — Red e infraestructura cloud	Firewalls, VPCs, segmentación e IAM en AWS, Azure y GCP.

Dominio → Subproceso → Actividad de control

Nivel	Qué es	Pregunta que responde el auditor	Propósito metodológico	Ejemplo
1. Dominio de TI	Categoría macro o área de gobierno tecnológico que agrupa riesgos estructurales de una misma naturaleza (Accesos, Cambios, Desarrollo, Operaciones).	¿Qué gran frente o pilar de la infraestructura estamos evaluando?	Establecer los objetivos de control para proteger confidencialidad, integridad y disponibilidad.	Acceso a Programas y Datos
2. Subproceso / componente	Engranaje operativo específico dentro de un dominio que gestiona un flujo técnico determinado.	¿Qué circuito o procedimiento interno de TI funciona en el día a día?	Delimitar la población de transacciones y activos sujetos a evaluación.	Gestión de bajas; cuentas privilegiadas; backups
3. Actividad de control	La traba preventiva o de detección concreta (técnica o manual) para evitar que un riesgo se materialice en el subproceso.	¿Qué acción específica, evidencia o parámetro técnico mitiga el riesgo?	Objeto directo de la prueba (diseño y eficacia operativa sobre muestra o población).	Baja de usuario dentro de las 24 h con ticket aprobado

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

El ejemplo de la actividad de control («baja dentro de 24 h») es ilustrativo, armado para que quede claro el nivel; la clase da los ejemplos de subproceso (bajas, cuentas privilegiadas, backups).

⚠ IMPORTANTE PARA EL PARCIAL

Dominio = el gran frente · Subproceso = el circuito que funciona a diario · Actividad de control = lo que realmente se prueba.

4.3.2 Dominio 1 — Acceso a Programas y Datos

Elemento	Contenido
Objetivo de control	Proteger a la entidad del acceso inapropiado y el uso no autorizado de los sistemas, asegurando segregación de funciones, confidencialidad e integridad .
Riesgos	Usuarios que eluden controles de autorización en aplicaciones; cuentas privilegiadas (superusuarios) modificando datos «en caliente»; contraseñas débiles o sin MFA ; empleados dados de baja con cuentas activas en producción; también (tabla de riesgos): cambios directos incorrectos a datos maestros y controles de seguridad de red débiles.
Subprocesos	Gestión del ciclo de vida de identidades (altas, modificaciones, bajas) · cuentas privilegiadas · parámetros de autenticación · revisión periódica de accesos (UAR).

Altas, modificaciones y bajas (IAM)

Subproceso	Control esperado	Evidencia esperada	Prueba del auditor
Altas	Solicitud formal, aprobación de jefatura y asignación de perfiles por roles (RBAC).	Formulario/ticket de autorización y perfil asignado.	Muestreo de usuarios creados en el período: verificar el formulario de autorización y que el perfil sea adecuado.

Subproceso	Control esperado	Evidencia esperada	Prueba del auditor
Modificaciones y cambios de puesto	Ajuste o revocación inmediata de permisos anteriores ante transferencias internas.	Ticket de cambio de rol; permisos previos revocados.	Comparar cambios de puesto con permisos vigentes.
Bajas	Notificación formal y oportuna de RR.HH. a TI para deshabilitar credenciales en todos los sistemas.	Listado de bajas de RR.HH. y estado de cuentas en AD y ERP.	Cruce masivo RR.HH. vs. sistemas: extraer el 100% de las bajas del año, cruzar la nómina contra la base de usuarios de Active Directory y ERP e identificar cuentas activas posteriores a la fecha de egreso.

EJEMPLO

RR.HH. informa la baja de un empleado el 10/3. El auditor cruza el listado con Active Directory y detecta que la cuenta sigue activa el 20/3: **excepción** (baja no oportuna) → riesgo: acceso indebido a producción.

Cuentas privilegiadas y superusuarios

Son el **mayor vector de riesgo en TI**: cuentas capaces de **eludir reglas de negocio, desactivar restricciones y alterar registros** directamente en la base (sa, postgres, root, Domain Admins).

- **Uso excepcional y nominativo:** prohibir cuentas genéricas compartidas.
- **Soluciones PAM:** bóvedas de contraseñas, grabación de sesión y rotación.
- **Monitoreo de logs inmutables** de los comandos ejecutados en producción.

Parámetros de autenticación y seguridad lógica

Parámetro	Qué se evalúa
Longitud y complejidad	Mínimo de caracteres, combinación alfanumérica y símbolos.
Bloqueo por intentos fallidos	Bloqueo automático tras 3 a 5 intentos erróneos (mitiga fuerza bruta).
Expiración y rotación	Vigencia máxima (60/90 días) e historial de contraseñas.
Doble factor (MFA/2FA)	Obligatorio en accesos remotos (VPN), paneles cloud y consolas de administración.

Prueba del auditor: revisar la configuración (inspección) e intentar el escenario (prueba de control), p. ej. ingresar una contraseña incorrecta 5 veces y verificar el bloqueo.

Revisión periódica de accesos (UAR — User Access Review)**UAR**

DEFINICIÓN → Proceso **recurrente (trimestral o semestral)** donde los **dueños de los procesos de negocio** revisan el listado completo de usuarios activos y **confirman la pertinencia de sus permisos**.

EN AUDITORÍA → Validar que la revisión abarcó el **100% de los usuarios y perfiles**, y que los accesos marcados para revocar **fueron eliminados sin demora indebida**.

CLAVE PARA EL PARCIAL → UAR: los dueños del negocio revisan, el auditor comprueba el 100% y que se revoque lo marcado.

CLAVE PARA EL PARCIAL → *Segregación de funciones y menor privilegio se sostienen con roles bien asignados (RBAC) + UAR + bajas oportunas.*

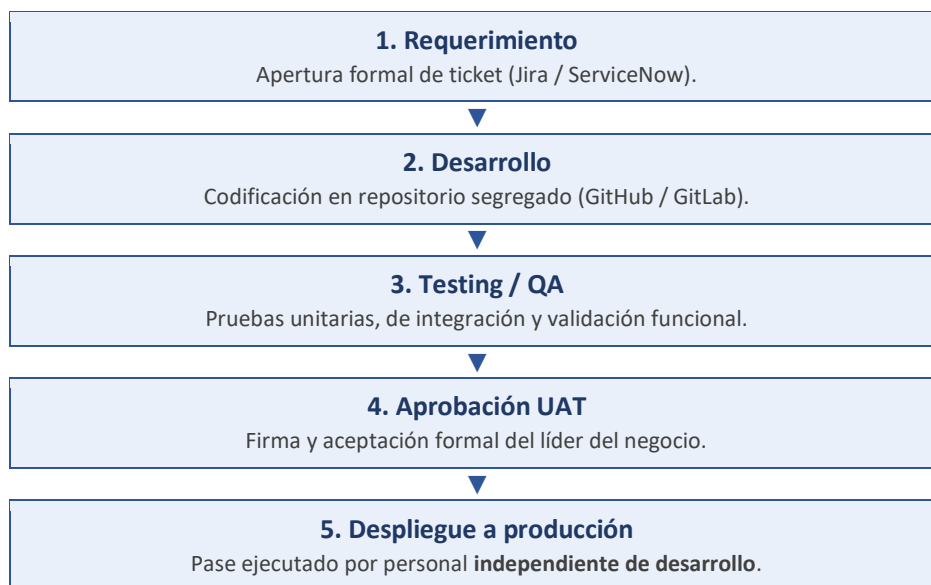
⚠ IMPORTANTE PARA EL PARCIAL

Dominio 1: altas (formulario + aprobación), bajas (cruce 100% RR.HH. vs. AD/ERP), privilegiadas (PAM, nominativas, logs), autenticación (MFA, bloqueo, rotación) y UAR (100%).

4.3.3 Dominio 2 — Gestión de Cambios en Programas

Elemento	Contenido
Objetivo de control	Garantizar que todos los cambios en aplicaciones e infraestructura se soliciten, autoricen, desarrollen, prueben e implementen adecuadamente.
Riesgos	Pases a producción con código no probado que causen errores contables; modificaciones fraudulentas en algoritmos de cálculo; cambios directos «en caliente» sin ticket ni control; cambios no autorizados o no probados que impiden procesar de forma completa y precisa.
Subprocesos	Ciclo de vida del cambio · segregación de ambientes y despliegue · cambios de emergencia.

Ciclo de vida del cambio



Segregación de ambientes (DEV / QA-UAT / PROD)

Desarrollo (DEV) —► Pruebas / Homologación (QA / UAT) —► Producción (PROD)

- **Regla inquebrantable de SoD:** los **programadores no deben tener permisos de escritura, administración ni despliegue** en servidores o bases de **Producción**.
- Los pases a producción los ejecutan **Operaciones / DevOps** o se automatizan con **pipelines CI/CD auditados**.

Prueba del auditor en cambios

Paso	Qué hace el auditor (evidencia esperada)
Población y muestreo	Extrae el listado completo de cambios del período y selecciona una muestra representativa de cambios estándar y de emergencia .
Aprobación previa	Verifica la aprobación por el Comité de Cambios (CAB) .
Pruebas	Constata evidencia documental de QA y UAT aprobadas .
Ventana de pase	Valida en los logs productivos que fecha y hora del pase coincidan con la ventana autorizada .

EJEMPLO

El auditor toma 25 cambios del año. En 24 hay ticket, QA/UAT y aprobación del CAB. En 1 el pase se hizo a las 3 a. m. sin aprobación previa: **excepción**. Si además los programadores tienen escritura en PROD, es una **deficiencia de diseño** (falla de SoD).

Cambios de emergencia

Cambio de emergencia

DEFINICIÓN → Modificaciones **urgentes fuera del ciclo estándar** para resolver **incidentes críticos o caídas** de servicio en producción.

OBJETIVO → Permitir reaccionar rápido **sin perder control**.

EN AUDITORÍA → **Controles compensatorios exigibles**: (1) **aprobación posterior** (post-implementation review) en un plazo formal máximo (ej. **24 a 48 h**); (2) **justificación técnica vinculada al ticket de soporte** original; (3) **pruebas retrospectivas completas de no regresión** en QA. El auditor verifica esos tres puntos sobre la muestra de emergencias.

CLAVE PARA EL PARCIAL → *Emergencia = se salta el orden, no el control: aprobación posterior, ticket de soporte y pruebas retrospectivas.*

⚠ IMPORTANTE PARA EL PARCIAL

Dominio 2: ticket → desarrollo → QA → UAT → pase por personal independiente; DEV/QA/PROD separados; programadores sin escritura en PROD; CAB; cambios de emergencia con aprobación posterior 24–48 h.

4.3.4 Dominio 3 — Desarrollo e Implementación de Programas

Elemento	Contenido
Objetivo de control	Garantizar que los nuevos sistemas o módulos se diseñen, configuren, prueben y migren adecuadamente para cumplir los requerimientos de la gerencia.
Riesgos	Sistemas recién implementados (o muy mejorados) que procesan datos de forma incompleta o imprecisa (codificación o configuración errónea); registros de transacciones y datos maestros no migrados de forma completa y precisa .

Elemento	Contenido
Subprocesos (SDLC)	Definición de requerimientos y diseño · migración de datos (data conversion) · aprobación final de salida en vivo (go-live).

Aspecto	Dominio 2 — Cambios	Dominio 3 — Desarrollo e Implementación
Naturaleza	Modificaciones incrementales o parches sobre sistemas existentes.	Adquisición, construcción o reemplazo integral de un ERP o migración estructural de infraestructura.
Ejemplo	Parche que corrige un cálculo de intereses.	Reemplazar el ERP completo por uno nuevo.

Controles críticos en proyectos de TI (SDLC)

Control	Qué exige	Evidencia / prueba esperable
1. Definición de requerimientos y diseño	Especificación formal de controles de validación contable y reglas de seguridad.	Documento de requerimientos y diseño con los controles especificados.
2. Migración de datos (data conversion)	Conciliación cruzada de saldos y registros entre el sistema legado y el nuevo; validación de C&A de las tablas maestras migradas.	Conciliaciones de saldos legado vs. nuevo; pruebas de completitud y exactitud.
3. Aprobación final de salida en vivo (go-live)	Autorización formal del Directorio y comités de dirección previa al corte .	Acta o autorización formal previa al go-live.

COMPLEMENTO DE TU RESUMEN (no está en las diapositivas)

En este dominio las diapositivas dan los controles pero no detallan pruebas paso a paso. La columna «evidencia / prueba» se armó directamente de lo que cada control exige (conciliar, validar C&A, exigir autorización formal); es una consecuencia lógica de la clase, no un texto literal.

EJEMPLO

Se migra el ERP: el auditor concilia el total de saldos de clientes del sistema legado contra el nuevo y valida que la tabla maestra migrada tenga todos los registros (**completitud**) y los campos correctos (**exactitud**). Antes del corte verifica el acta de autorización del Directorio.

⚠ IMPORTANTE PARA EL PARCIAL

Dominio 3 = proyectos grandes (nuevo ERP/migración): requerimientos formales, migración con conciliación y C&A, aprobación formal de go-live. No confundir con cambios incrementales (Dominio 2).

4.3.5 Dominio 4 — Operaciones de Cómputo

Elemento	Contenido
Objetivo de control	Garantizar que el procesamiento de datos sea completo, exacto y oportuno , y que ante fallas operativas o desastres los datos puedan recuperarse íntegramente .
Riesgos	Cambios inadecuados, intervención manual o fallos en procesos por lotes ; transacciones perdidas (falta del sistema) que no se recuperan o se corrompen/duplican en la recuperación; transferencias entre sistemas incompletas o inexactas ; acceso no autorizado a instalaciones, equipos y recursos.
Subprocesos / componentes	Procesamiento por lotes (batch jobs) e interfaces · backups y almacenamiento · DRP y BCP · seguridad física y ambiental de centros de cómputo.

Procesamiento por lotes (batch jobs) y monitoreo

Naturaleza: tareas automatizadas programadas que consolidan transacciones masivas **fuera del horario comercial** (cierre contable diario, devengo de intereses).

- **Monitoreo automatizado** del estado de ejecución (exitoso, advertencia, fallido).
- **Registro y alerta inmediata** ante interrupciones de procesos en cola.
- **Protocolo formal para reiniciar y reintentar** trabajos abortados **sin duplicar transacciones**.

Prueba del auditor: revisar logs de ejecución y del monitoreo; observar a un operador ejecutando un batch nocturno (observación directa); verificar el protocolo de reintento. (Ver también el control de interfaces **CO.01**, monitoreo y resolución de lotes.)

Estrategia de backups

Elemento	Qué exige
Regla 3-2-1	3 copias de los datos, en 2 soportes diferentes, con 1 copia fuera del sitio (offsite o región cloud aislada).
Cifrado	En tránsito y en reposo (AES-256) para proteger la confidencialidad.
Retención e inmutabilidad	Bloqueo WORM (Write Once, Read Many) para prevenir secuestro o borrado de respaldos ante ransomware .

Pruebas de auditoría sobre backups

DEFINICIÓN → La falsa seguridad del respaldo: tener un backup configurado **no garantiza poder restaurarlo**.

EN AUDITORÍA → (1) Revisar los **registros automáticos de ejecución diaria y semanal** y constatar estado **exitoso**. (2) Inspeccionar **pruebas de restauración:** exigir **evidencia documental (actas y capturas)** de restauraciones periódicas en **ambientes aislados**.

CLAVE PARA EL PARCIAL → Backup sin prueba de restauración = falsa seguridad.

Continuidad del negocio y recuperación (DRP / BCP): RPO y RTO

Métrica	Significado	Ejemplo de la clase
RPO — Recovery Point Objective	Máxima pérdida tolerable de datos , medida en tiempo.	RPO = 1 hora: se tolera perder hasta 60 minutos de transacciones.
RTO — Recovery Time Objective	Máximo tiempo tolerable de inactividad para restablecer el servicio.	RTO = 4 horas.

Prueba del auditor: evaluar si la infraestructura y la **frecuencia de backups** permiten cumplir técnicamente los RPO y RTO definidos por el negocio.

CLAVE PARA EL PARCIAL → *RPO = cuántos DATOS puedo perder · RTO = cuánto TIEMPO puedo estar caído.*

Seguridad física y ambiental

Entorno	Controles / prueba
Centros de cómputo on-premise	Acceso biométrico o tarjeta magnética y registro de visitas; climatización, detección y extinción de incendios por gas limpio ; UPS y grupos electrógenos.
Entornos en la nube (AWS / Azure / GCP)	Se evalúa la seguridad física revisando el informe SOC 1 / SOC 2 Tipo II emitido por el auditor del proveedor cloud.

EJEMPLO

El auditor revisa los logs del backup diario del ERP (todos «exitosos») pero pide el acta de la última prueba de restauración: no existe desde hace 14 meses → **deficiencia**: no hay evidencia de que los backups sean recuperables (riesgo para RPO/RTO).

⚠ IMPORTANTE PARA EL PARCIAL

Dominio 4: batch jobs (monitoreo, alertas, reintento sin duplicar), backups 3-2-1 con cifrado y WORM, pruebas de restauración, RPO/RTO (DRP/BCP) y seguridad física (o SOC en la nube).

4.3.6 Los cuatro dominios ITGC: cuadro comparativo

Dominio	Objetivo	Riesgo típico	Controles centrales	Prueba típica
Acceso a Programas y Datos	Evitar acceso inapropiado; SoD, confidencialidad e integridad.	Bajas sin deshabilitar; superusuarios; contraseñas débiles.	RBAC, altas/bajas formales, PAM, MFA, UAR.	Muestreo de altas; cruce 100% de bajas; UAR al 100%.
Gestión de Cambios	Cambios solicitados, autorizados, probados e implementados.	Código no probado; cambios en caliente.	Ticket, QA/UAT, CAB, DEV/QA/PROD, SoD.	Población de cambios, evidencia QA/UAT, logs de pase.
Desarrollo e Implementación	Sistemas nuevos bien diseñados, probados y migrados.	Migración incompleta o inexacta.	Requerimientos formales, conciliación con C&A, go-live formal.	Conciliar legado vs. nuevo; acta de autorización.
Operaciones de Cómputo	Procesamiento completo, exacto, oportuno y recuperable.	Batch fallidos; pérdida de datos.	Monitoreo de jobs, backups 3-2-1, DRP/BCP, seguridad física.	Logs de backup y pruebas de restauración; RPO/RTO.

4.3.7 Riesgos de TI por dominio (tabla de la clase)

Dominio	Consideraciones de riesgo
Desarrollo de programas	Sistemas recién implementados o muy mejorados procesan datos de forma incompleta o imprecisa (codificación o configuración errónea). Los registros de transacciones y datos maestros no se migran de forma completa y precisa.
Cambio de programa	Cambios no autorizados o no probados, o falta de los cambios necesarios en aplicaciones, configuraciones, procesos por lotes o SO/red, impiden procesar de forma completa y precisa. Se realizan cambios directos incorrectos en registros de transacciones o datos maestros.
Operaciones informáticas	Cambios inadecuados, intervención manual o fallos en procesos por lotes. Registros de transacciones perdidos (falla del sistema) y no recuperables, o corruptos/duplicados en la recuperación. Registros transferidos entre sistemas incompletos o inexactos. No se impide el acceso no autorizado a instalaciones, equipos y recursos.
Acceso a programas y datos	Usuarios finales eluden controles de autorización y SoD. Cuentas de alto riesgo (superusuario) eluden controles. Cambios directos incorrectos a registros o datos maestros. Contraseñas débiles o configuraciones de seguridad permiten eludir derechos de acceso. Seguridad de red débil permite acceso no autorizado a sistemas financieramente significativos.

4.3.8 Modelo de las 5 C (redacción técnica de hallazgos)

Modelo de las 5 C

DEFINICIÓN → Estructura obligatoria de **toda observación** en un papel de trabajo o informe: **Condición, Criterio, Causa, Consecuencia y Corrección/Recomendación**.

OBJETIVO → Que el hallazgo sea claro, fundamentado y accionable: qué pasó, contra qué se compara, por qué pasó, qué riesgo implica y qué hacer.

CLAVE PARA EL PARCIAL → *Condición = HECHO · Criterio = DEBER SER · Causa = RAÍZ · Consecuencia = RIESGO · Corrección = ACCIÓN.*

C	Pregunta	Significado	Ejemplo aplicado (clase)
1. Condición	¿Cuál es la situación actual encontrada?	El hecho real .	5 programadores mantienen privilegios de administración (root) en la base de datos productiva.
2. Criterio	¿Cuál era la norma, política o estándar aplicable?	El deber ser .	La Política de Seguridad P-04 exige segregación de ambientes y prohíbe accesos de escritura a desarrolladores en producción.
3. Causa	¿Por qué ocurrió el problema?	La raíz de la falla.	Ausencia de un proceso formal de revisión periódica de accesos de TI.
4. Consecuencia	¿Cuál es el riesgo o impacto potencial para el negocio?	El riesgo/impacto .	Riesgo de manipulación no autorizada de saldos o alteración de registros contables sin trazabilidad .
5. Corrección / Recomendación	¿Qué acción específica debe implementar la gerencia?	La acción a tomar.	Revocar privilegios de inmediato y configurar cuentas de solo lectura con logs inmutables .

⚠ IMPORTANTE PARA EL PARCIAL

Las 5 C: Condición, Criterio, Causa, Consecuencia, Corrección. El ejemplo del profesor: 5 programadores con root en la base productiva (Dominio 1: acceso/cuentas privilegiadas + SoD).

Más ejemplos armados con las 5 C (prácticos, para entrenar)

Bajas (Dominio 1): *Condición:* 3 usuarios dados de baja en RR.HH. seguían activos en el ERP. *Criterio:* la política exige deshabilitar accesos al egreso. *Causa:* RR.HH. no notifica formalmente a TI. *Consecuencia:* acceso indebido a datos financieros. *Corrección:* deshabilitar las cuentas y formalizar la notificación.

Cambios (Dominio 2): *Condición:* 2 de 25 pases sin aprobación del CAB. *Criterio:* todo cambio requiere aprobación previa. *Causa:* no hay bloqueo técnico en el pipeline. *Consecuencia:* código no probado en producción. *Corrección:* exigir aprobación como paso obligatorio del pipeline.

(Ejemplos ilustrativos armados sobre los controles de la clase; los datos numéricos son inventados solo para practicar.)

4.3.9 ¿Cómo se relaciona todo esto?**¿Cómo se relaciona todo esto?**

Riesgo → Control → Evidencia → Prueba del auditor → Hallazgo en los ITGC:

- **Riesgo:** empleados dados de baja con cuentas activas.
- **Control (actividad de control):** baja formal notificada por RR.HH. y deshabilitación inmediata.
- **Evidencia:** listado de bajas de RR.HH., estado de cuentas en AD/ERP, tickets.
- **Prueba:** cruce masivo del 100% de las bajas contra AD y ERP.
- **Hallazgo (5 C):** si hay cuentas activas post-egreso → condición, criterio, causa, consecuencia y corrección.

Dominio → Subproceso → Actividad de control: Acceso a Programas y Datos → Gestión de bajas → «deshabilitar credenciales dentro del plazo». Lo que se **prueba** es la actividad de control.

ITGC ↔ Módulo 2: los cuatro dominios son el cimiento de la cadena FSLI → LSPM → control clave → dependencia de TI → aplicación → ITGC. Si un dominio falla, cae la confianza en todo lo que apoya (y el auditor pasa a pruebas sustantivas amplias con CAATs).

Autoevaluación del Módulo 3

LO QUE DEBO PODER EXPLICAR SIN MIRAR

1. ¿Qué es un ITGC y por qué respalda a los controles de aplicación y las dependencias de TI?
2. Nombrá los 4 dominios y las 4 capas de la pila tecnológica auditada.
3. Diferenciá Dominio → Subproceso → Actividad de control con un ejemplo.
4. Dominio 1: ¿cómo se prueban las altas, las bajas y las cuentas privilegiadas? ¿Qué es la UAR?
5. ¿Qué parámetros de autenticación evalúa el auditor?
6. Describí el ciclo de vida del cambio y la segregación DEV / QA-UAT / PROD.
7. ¿Qué controles compensatorios se exigen en un cambio de emergencia?
8. Diferenciá Gestión de Cambios (Dominio 2) de Desarrollo e Implementación (Dominio 3).
9. Explicá batch jobs, la regla 3-2-1, WORM y por qué hay que probar la restauración.
10. Definí RPO y RTO y explicá qué evalúa el auditor.
11. Enunciá y aplicá el Modelo de las 5 C al caso de programadores con root en producción.

ANEXO — Análisis de fuentes: qué se corrigió y qué se agregó

Comparación entre las **diapositivas** (fuente principal) y tu **resumen en PDF** (fuente secundaria). Este anexo no es para memorizar: sirve para saber qué reforzar.

A.1 Temas que aparecen en las clases

- **Clase 1 / Unidad 1:** auditoría, objetivos, tipos, normas y ética, auditoría de SI y misión, controles P/D/C, ITGC vs. aplicación, control interno y sus tipos, política-plan-normas-medidas, control interno vs. auditoría, COSO.
- **Clase 2 / Unidad 2:** función, independencia/objetividad/evidencia, CID, departamento, interna vs. outsourcing, roles, programa y cronograma anual, perfil, CISA, ética, triángulo del fraude, normas y estándares, ISACA, COBIT, COSO vs. COBIT.
- **Clase 3 / Unidad 3:** auditoría de cumplimiento, SOX (origen, objetivos, secciones, proceso, PCAOB, aplicabilidad, Argentina), SOC 1, SOC 2, SOC 3, CUEC, familia SOC, AICPA/CPA/SSAE 18/TSC, PCAOB vs. AICPA.
- **Clase 4 / Módulo 1:** rol del auditor, integrada vs. no integrada, riesgo de auditoría, seguridad razonable, RI/RC/RD/RMM, matriz de riesgo, procedimientos, CAATs, pruebas de cumplimiento vs. sustantivas, evidencia, papeles de trabajo, excepción vs. deficiencia, 5 C, informe.
- **Clase 5 / Módulo 2:** Top-Down, FSLI, LSPM, controles clave, ICFR (ELC, proceso, ITGC), tipología (manual/automatizado/ITDM), periodicidad, cinco dependencias de TI, pila tecnológica, ITGC como cimiento, RCM.
- **Clase 6 / Módulo 3:** ITGC, pila tecnológica, dominio→subproceso→actividad, cuatro dominios, 5 C.

A.2 Lo que ya estaba bien explicado en tu resumen

- Unidad 1: definición, tipos de auditoría, normas generales, misión, P/D/C, control interno y sus cuatro tipos, comparativa CI vs. auditoría, COSO completo (objetivos, componentes, cubo).
- Unidad 2: elementos clave, CID, organización, programa de auditoría, perfil/CISA, ética e ISACA, marcos, COBIT (dominios, gobierno vs. gestión), COSO vs. COBIT.
- Unidad 3: definición, pasos, SOX (objetivos, secciones, PCAOB, aplicabilidad, proceso), SOC 1 (Tipo I y II), SOC 2 y comparación SOC 1 vs. SOC 2.
- Unidad 4: procedimientos, papeles de trabajo, informe, integrada vs. no integrada, RI/RC/RD, FSLI/LSPM, ELC/proceso/ITGC, key reports, SoD/RA, interfaces.

A.3 Lo que faltaba o estaba incompleto en tu resumen

Tema (diapositivas)	Estado en tu resumen	Qué se hizo
Ejemplos de ITGC vs. control de aplicación (SYSACAD); política-plan-normas-medidas; ciclo del control interno; relación CI-auditoría (objeto/examen, dependencia metodológica, retroalimentación)	Faltaban	Se incorporaron en Unidad 1.
Caso del DBA (ética/independencia); objetivos de la auditoría; misión vs. objetivos	Faltaban	Se incorporaron en Unidad 1.
Interna vs. outsourcing; roles; cronograma anual (WT, Interim 80%, LCD/Updates 20%, cierre); triángulo del fraude	Faltaban (solo mencionabas «roles» y las 3 fases)	Se incorporaron en Unidad 2.

Tema (diapositivas)	Estado en tu resumen	Qué se hizo
Mapa COBIT: procesos por dominio, DSS04, uso práctico del mapa	Faltaba el detalle de procesos	Se agregó en Unidad 2.
Enron y WorldCom; SOX en Argentina; sanción de la 906; impacto de SOX en sistemas (404/802); CUEC; SOC 3; familia SOC; AICPA/CPA/SSAE 18/TSC; PCAOB vs. AICPA	Faltaban	Se incorporaron en Unidad 3.
Seguridad razonable; RMM; relación inversa RC–RD; matriz P×I; CAATs; reperformance como evidencia más sólida; efecto Hawthorne; pruebas de cumplimiento vs. sustantivas; suficiencia/adecuación; estructura de la cédula; excepción vs. deficiencia; modelo de las 5 C; «¿por qué es una opinión?»	Faltaban	Se incorporaron en Módulo 1.
Cadena Top-Down completa; control clave; tipología manual/automatizado/ITDM y su prueba; periodicidad; C&A y estrategias A/B/C; hash totals; riesgos de EUC; incompatibilidades SoD; menor privilegio; RCM y ejemplo de nómina; actividad del analista contable	Faltaban o eran parciales	Se desarrollaron en Módulo 2.
Módulo 3 completo: dominios, subprocesos, altas/bajas, PAM, autenticación, UAR, ciclo del cambio, cambios de emergencia, SDLC, batch jobs, 3-2-1, RPO/RTO, seguridad física	No estaba en tu resumen	Se desarrolló completo en Módulo 3.

A.4 Contradicciones o contenido de tu resumen que NO está respaldado por las clases

Punto	Tu resumen	Diapositivas	Decisión
SOX 906	Sin sanciones («-»).	Hasta \$5 millones y/o 20 años.	Se usó la diapositiva.
SOX 404 y sanciones	«Incumplimiento resulta en informe adverso».	No lo menciona.	Quedó como nota; no obligatorio.
Cubo COSO — ejemplo con SOX	Incluido en detalle.	Solo el título «Ejemplo práctico del cubo en acción» (las láminas son imágenes).	Se mantuvo como ejemplo (etiquetado).
Baseline vs. Benchmarking	Definidos.	No hay lámina específica en el Módulo 2.	Se incluyó con nota; confirmar si entra.
Interfaces: 16 muestras; SoD/RA en 5 pasos	Incluidos.	No figuran así.	Se incluyeron como complemento etiquetado.
Tabla «deficiente vs. adecuada» de controles SI para SOX	Incluida.	La idea está en «¿Por qué impacta en Sistemas?».	Se mantuvo como ejemplo etiquetado.
Texto «Perfecto, Matias... resumen para parcial» (dentro del resumen)	Es un resto de un texto generado.	—	Se descartó.
«Unidad N°5: Dependencias de TI»	Aparece como otra unidad.	Las dependencias son del Módulo 2 de la Unidad 4 .	Se ubicó en el Módulo 2.
«EUC (Contactos de usuario final)»	Traducción incorrecta.	EUC = End-User Computing .	Se corrigió.

A.5 Temas que reciben más desarrollo (prioridad de estudio)

- **Unidad 4 completa** es la de mayor extensión: 3 clases (≈92 láminas). Dentro de ella: **RI/RC/RD y qué controla el auditor, cadena Top-Down, ITDM + C&A, cuatro dominios ITGC y Modelo de las 5 C** (aparece en Módulos 1 y 3 y tiene ejemplo resuelto).
- **Unidad 3:** SOX (secciones 302/404/802/906), **SOC 1 Tipo I vs. II, SOC 1 vs. 2 vs. 3**, PCAOB vs. AICPA.
- **Unidad 2:** COBIT (dominios, gobierno vs. gestión) y su relación con COSO.
- **Unidad 1:** P/D/C, ITGC vs. aplicación, COSO.

Los conceptos que se repiten en varias clases (independencia, ITGC, SoD, C&A, evidencia, SOX 404) son los que más conviene dominar.

Recordatorio final

Este material se armó únicamente con el contenido de tus diapositivas y de tu resumen. Todo lo etiquetado como «COMPLEMENTO DE TU RESUMEN» no está respaldado por las láminas: usalo con criterio y confirmá con tu profesor si entra en el parcial.